

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Table of Contents

About the Practitioner's Blueprint for Secure AI Series	5
Series Preface: The Practitioner's Blueprint for Secure AI	8
Introduction to Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem	10
Author's Preface – Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem	13
Cybersecurity Multi-Agent AI Blueprint	14
Multi-Agent Cybersecurity Defensive Ecosystem — Domain Overview.....	14
Domain Agents and Coverage of SP 800-160v2 Techniques and Approaches.....	15
Domain A – GRC & Oversight	15
Domain B – Asset, Configuration, and Change Management	17
Domain C – Identity, Credential, and Access Management (ICAM)	18
Domain D – Threat Intelligence, Situational Awareness, and Monitoring	19
Domain E – Protective Technologies & Hardening	21
Domain F – Data Security & Privacy	22
Domain G – Incident Response & Digital Forensics (IR-DFIR)	23
Domain H – Resilience, Continuity, and Recovery	24
Domain I – Security Architecture & Systems Engineering (SASE)	25
Domain J – Physical & Environmental Security.....	26
Domain K – Supply Chain & Lifecycle Security	28
Domain L – Security Program Enablement	28
Building an AI Agent with Examples	29
AI for Cybersecurity Staff	30
Bridging GRC Program Oversight with AI Agent Implementation	30
How an AI Agent is Built – With Examples	32
Cybersecurity Context for AI Developers	40
High-Level Development and Deployment Guide	42
How the Domains Interconnect.....	47
Manual Document Inputs and Outputs	48
Data Flows.....	55
Domain A – Governance, Risk, and Compliance (GRC) & Oversight.....	56
Domain B – Asset, Configuration, and Change Management	58

Domain C – Identity, Credential, and Access Management (ICAM)	60
Domain D – Threat Intelligence, Situational Awareness, and Monitoring	62
Domain E – Protective Technologies & Hardening	64
Domain F – Data Security & Privacy	67
Domain G – Incident Response & Digital Forensics (IR-DFIR)	70
Domain H – Resilience, Continuity, and Recovery	72
Domain I – Security Architecture & Systems Engineering (SASE)	74
Domain J – Physical & Environmental Security	76
Domain K – Supply Chain & Lifecycle Security	78
Domain L – Security Program Enablement	80

About the Practitioner's Blueprint for Secure AI Series

Artificial Intelligence is no longer an emerging technology. It is embedded in the workflows of enterprises, governments, and societies at large. Generative models, autonomous agents, and multi-agent ecosystems now power decision-making, operations, and innovation at scale. Alongside these benefits, however, comes a stark reality: AI creates risks that traditional cybersecurity frameworks were never designed to handle.

From prompt injection attacks against Large Language Models (LLMs) to the urgent need for post-quantum cryptography (PQC) in response to harvest-now, decrypt-later threats, the security landscape is shifting faster than many organizations can adapt. The convergence of quantum computing, high-performance computing (HPC), and AI infrastructures introduces new dependencies and attack surfaces. These shifts will test encryption schemes, challenge existing trust models, and demand stronger resilience across digital infrastructure.

This series — *The Practitioner's Blueprint for Secure AI* — exists to close that gap.

Why This Series Exists

Security professionals, architects, and practitioners are already grappling with AI- and quantum-related risks, yet most resources remain fragmented. Academic research often lacks operational applicability, while vendor solutions can be narrow, proprietary, or untested at scale.

What practitioners need are blueprints: clear, field-tested reference models that can be adapted to their specific environments. These blueprints must go beyond theory to provide:

- **Actionable defensive patterns** grounded in real threats.
- **Architectural frameworks** that scale across enterprises.
- **Immediate imperatives** such as PQC migration and AI-specific defenses.
- **Forward-looking guidance** for hybrid infrastructures and quantum-era challenges.

This series was written to provide that foundation — practical enough to use today, but extensible enough to remain relevant tomorrow.

The Structure of the Series

The *Practitioner's Blueprint for Secure AI* is divided into three volumes. Each book can be read on its own, but together they form a progression: from the urgent problems of today, to the systemic architectures of tomorrow, to the frontier challenges of the quantum era.

- **Volume 1: Securing Generative AI and Other Neural Networks – A Practitioner's Blueprint**
Focuses on defending LLMs, agents, and autonomous systems. It addresses immediate risks such as data poisoning, adversarial prompting, and runaway autonomous loops, offering countermeasures that practitioners can implement in production systems today.
- **Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem**
Expands the lens from individual models to an integrated ecosystem of defensive agents. Structured across twelve security domains — from governance and identity to incident response and supply chain assurance — it defines a modular but cohesive architecture for enterprise-scale AI defense.
- **Volume 3: Advanced Foundations for Secure AI in the Quantum Era**
Addresses current imperatives such as post-quantum cryptography migration, while also preparing practitioners for frontier challenges. It examines hybrid HPC–quantum infrastructures, logical quantum machine security, and advanced integration patterns for AI in a quantum-enabled world. This volume emphasizes that PQC is not optional foresight but a present-day necessity.

Who This Series Is For

This series is intended for those responsible for making AI secure in practice, including:

- **Security architects and engineers** designing and deploying systems.
- **CISOs, governance leaders, and risk officers** aligning AI security with organizational and regulatory requirements.
- **Developers, data scientists, and AI practitioners** working with generative models, autonomous agents, and hybrid infrastructures.
- **Policy shapers and compliance professionals** tasked with setting standards for AI and PQC security in regulated industries.

Each volume is written with practitioners in mind: concise where possible, detailed where necessary, and always focused on application.

How to Use This Series

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **Standalone or Sequential:** Each volume stands on its own but also builds toward the next. Readers may start with the volume most relevant to their current challenges.
 - **Blueprint Orientation:** Frameworks, specifications, and examples are presented as adaptable patterns, not rigid prescriptions. Practitioners are encouraged to adapt them to fit their environments.
 - **Progression:** The series moves from tactical defenses (Vol. 1) to systemic architectures (Vol. 2) to advanced infrastructures and quantum imperatives (Vol. 3).
-

A Living Framework

The title *Blueprint* is intentional. These volumes are designed not as final answers but as structured foundations practitioners can build upon, extend, and evolve. AI security is a moving target, and no single framework will remain static.

Importantly, some topics once considered “future-looking” are now present-day imperatives. **Post-quantum cryptography is one such example: the need to migrate is immediate, not optional.** This series treats it accordingly, while also extending into emerging areas such as hybrid HPC–quantum environments and logical quantum machine security.

Together, these three volumes form a comprehensive guide — equipping practitioners to defend the present, build resilient ecosystems, and meet both current and future challenges of securing AI in a quantum-enabled world.

Series Preface: The Practitioner’s Blueprint for Secure AI

When I began my career in technology, I did not anticipate that it would eventually lead me into the convergence of artificial intelligence, cybersecurity, and quantum computing. From my earliest days in systems design and engineering through decades in software configuration, release management, and security architecture, the thread that has held constant is this: complex systems demand discipline, structure, and foresight. Without them, complexity metastasizes into fragility.

Artificial Intelligence has amplified both the promise and the fragility of our digital era. Long before “generative AI” became a household phrase, enterprises were already deploying neural networks in production. These early systems demanded governance, fairness, and controls—but it was the arrival of publicly exposed LLMs that truly catapulted AI into the center of cybersecurity discourse. With exposure came creative misuse: prompt injection, adversarial manipulation, model drift, and governance failures. The vulnerabilities are novel, but the lesson is old: systems deployed without guardrails will eventually be compromised.

Volume 1 of this series, *Securing Generative AI and Other Neural Networks*, takes that problem head on. It supplements traditional security frameworks with model governance and defense patterns tailored to generative systems. It assumes practitioners already know NIST controls; what it offers instead are focused, field-tested ways to address the new attack surfaces of exposed AI.

Volume 2, *The Multi-Agent AI Defensive Cybersecurity Ecosystem*, expands the scope from individual models to the system-of-systems level. Here the challenge is not a single LLM or pipeline but the entire defensive landscape: multiple agents, each proprietary, each racing to integrate AI. The absence of producer liability has left us stitching together patches and vendor tools. This volume proposes an open-source management overlay, rooted in NIST SP 800-160v2 and validated against CISA HVA security assessments, to impose coherence where market forces have not. The intent is not to replace tools, but to orchestrate them, providing a common structure to wrangle complexity at scale.

Volume 3, *Advanced Topics in Secure AI for the Quantum Era*, looks toward the frontier. My own journey into quantum began in 2019 with a spark at Oxford, leading to patents, training programs, and a conviction that hybrid HPC–quantum–AI infrastructures will reshape both attack surfaces and defensive opportunities. This volume treats post-quantum cryptography (PQC) not as foresight but as a current imperative—mandated already by government, and overdue for enterprise adoption. From there it moves into the unique security demands of high-dimensional data, insider threats, and hybrid architectures.

But Volume 3 is not only about risk. It is equally about opportunity: how hybrid quantum–classical environments can be leveraged for material discovery, secure high-dimensional analytics, and scaling defensive architectures that were previously infeasible. The same hybrid infrastructures that introduce new trust models also open the door to cybersecurity solutions at a scale and fidelity beyond classical limits. The future is arriving quickly, and the only sustainable strategy is to treat quantum-era risks as present-day realities—while also preparing to seize the opportunities these architectures make possible.

I could spend years polishing and expanding these works, trying to make them exhaustive and perfect. But as Voltaire warned, *“the best is the enemy of the good.”* Waiting for perfection would only delay getting critical information into the hands of those who need it now. The same applies to the models, frameworks, and blueprints offered in these volumes. As statistician George Box observed, *“All models are wrong, but some are useful.”* The point is not perfection but utility—the essential question is always, *is it good enough to be useful?* My hope is that these volumes provide guidance that is immediately useful, while also serving as a foundation for future adaptation, correction, and extension.

Different communities approach taxonomy in different ways, and there is no single universally agreed system for categorizing AI, cybersecurity, and quantum-era risks. I am open to being convinced of better, more common taxonomies. What matters most is starting the conversation, sharing what is useful, and working toward approaches that can be broadly understood and applied across domains.

This series is not the final word. It is a set of blueprints—living frameworks designed for adaptation, extension, and evolution. Some patterns will become obsolete; others will harden into standards. But the purpose remains constant: to give practitioners a structured way to secure AI today while preparing for the realities of tomorrow.

— John M. Willis

Introduction to Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

If the first volume of this series focused on defending individual models and neural networks, this second volume shifts the lens outward to the ecosystem level. AI systems are rarely deployed in isolation. They operate as part of a wider environment of monitoring tools, governance structures, and defensive countermeasures. Securing these environments requires more than individual safeguards — it demands an integrated defensive architecture.

This volume presents a multi-agent cybersecurity ecosystem blueprint, structured across twelve domains. Each domain represents a defensive capability — from governance, risk, and compliance to threat intelligence, identity management, incident response, supply chain assurance, and beyond. Together, they form an orchestration layer: a management-level ecosystem that coordinates security functions across AI-driven infrastructures.

Why This Volume Is Different

This blueprint is **not a complete security manual**, nor does it attempt to replace the primary tools or platforms you already use. Instead, it provides:

- **A starting point:** The specifications and patterns here are reference points — both informative and normative — grounded in **NIST SP 800-160v2 (Systems Security Engineering)** and informed by comparisons to frameworks such as **CISA's High-Value Asset (HVA) security assessment**.
- **A management-layer perspective:** The ecosystem described here is intended to sit above your existing tools, orchestrating and coordinating them. It is **tool-agnostic by design**. If you change or add a tool, you only need to adjust the relevant interface.
- **Tailorability:** Even where a domain or agent specification appears complete, you must adapt it to your specific environment. This includes validating the specification for accuracy and completeness.
- **Prioritization guidance:** Practitioners will rarely be able to implement all twelve domains simultaneously. This blueprint encourages you to **prioritize** the most critical domains or groups of agents first, based on your risk profile and mission priorities.
- **Open development path:** The agent specifications described here will not remain static. They are being prepared for **release to open source**

development, potentially under the auspices of **OWASP or a comparable community security initiative**. Practitioners should expect these specifications to evolve with contributions from the wider security and AI community.

Practical Considerations and Limitations

It is important to be clear about what this volume **is not**:

- It does not provide step-by-step instructions for building models, training LLMs, or wiring agents together using protocols like MCP. It assumes the reader already has working knowledge of those areas.
- It does not guarantee full coverage of every function in every environment. Large, complex, or highly specialized systems may require tailoring beyond what is presented here.
- It may not always be practical — or even possible — to implement every specification described, given the technical, organizational, or resource constraints of your environment.

No warranty is expressed or implied. The material presented here is intended as guidance: a structured starting point for designing your own defensive ecosystem, not a finished product.

Structure of This Volume

This book is organized around the **twelve defensive domains** of the multi-agent ecosystem. Part 1 provides critical information to be able to utilize the Cybersecurity Multi-Agent AI Blueprint. It contains ones or more sets of Domain Agent Specifications. **Subsequent Parts of this Volume do not contain the explanatory material---they only contain Domain Agent Specifications.**

Each domain includes:

- A high-level description of its defensive role.
- An agent-level specification outlining functions, interactions, and dependencies.
- Mappings to relevant controls and standards.
- Notes on tailoring, prioritization, and known limitations.

The volume concludes with a discussion of how the twelve domains interconnect, forming a system-of-systems that can be orchestrated at the enterprise level.

How to Use This Volume

This blueprint is meant to be **adapted, not adopted wholesale**. Practitioners should:

- Treat it as a **management layer orchestration guide**, not a replacement for existing tools.
- Use it to **inform prioritization decisions** about which domains and agents to implement first.
- Tailor each specification to local context, ensuring that assumptions align with organizational realities.
- Recognize that some elements are deliberately underspecified, reflecting the diversity and complexity of real-world environments.

By following these principles, security architects and practitioners can leverage this volume to create a more resilient, adaptive, and coordinated defense against the risks of AI systems.

The Larger Series Context

This second volume extends the journey begun in *Volume 1: Securing Generative AI and Other Neural Networks*. Where the first book focused on defending individual models and neural architectures, this volume builds the **ecosystem architecture** necessary for enterprise-scale resilience.

Volume 3 will then move forward to address both the **current imperative of post-quantum cryptography** and the frontier challenges of securing and leveraging hybrid HPC–quantum–AI infrastructures.

Taken together, the three volumes form a progression:

- **Defend the model** (Volume 1).
- **Defend the ecosystem** (Volume 2).
- **Defend the future** (Volume 3).

This introduction situates Volume 2 as the **bridge between today’s tactical defenses and tomorrow’s systemic architectures** — a blueprint for orchestrating secure, multi-agent ecosystems that adapt to diverse environments and evolving threats.

Author's Preface – Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Before I was introduced to build and release engineering and software configuration management, I was a programmer team lead at MCI (that was a while ago!), working on some complex system “rocket science” programming. Prior to that, I implemented an OCR system for cataloging legal documents for a client. Before that, I worked at Marconi Avionics (since bought and sold so many times I’m not sure what to call them anymore). At Marconi I found my true calling — systems work.

I spent eight years there doing systems design, programming, and testing on a number of very interesting systems in a DoD environment. I had aced the electronics test and was hired as an Engineering Assistant in 1978, later promoted to Associate Engineer. Before Marconi, I had been an Electronics Technician fixing terminal equipment, including line printers, at a small company where I was expected to troubleshoot logic boards down to the component level using only a dual-probe oscilloscope. Those boards were 8-bit finite state machines. That job didn’t last long, but at Marconi I later worked with logic analyzers and built-in-test engineering, and I thoroughly enjoyed the challenges of control systems design.

All of these experiences positioned me to have a good grasp of **systems thinking**. Fast forward to my cybersecurity career: one of the enduring realities of software in our free economy is the absence of producer liability. We produce buggy code, then buy and sell tools to compensate for it. This model has benefits and drawbacks, but it has left us with a patchwork of vendor tools, each with its own interface, mostly proprietary, and each racing to bolt on AI in their own way.

This volume seeks to begin the process of open-sourcing a **management overlay** that provides a uniform structure to wrangle this chaos. The goal is not to replace tools, but to create a common language and infrastructure that allows practitioners to govern them coherently. If a vendor tool implements AI, the answer is not to rip it out — it’s simply to update the interface. The underlying management needs do not change.

The ecosystem of agentic AI presented here is rooted in **NIST SP 800-160v2**, and validated in part using the **CISA High-Value Asset security assessment questions** I was trained on when certified as a CISA HVA Assessor Technical Lead. Together, these foundations point toward an ecosystem oriented around high assurance and zero trust environments.

I look forward to working with readers and colleagues as these agent specifications move into open-source development — evolving into real agents that are extensible, adaptable, and ultimately serve the needs of practitioners across industries.

PART 1 – Overview of the Multi-Agent AI Blueprint and First Domain(s)

Cybersecurity Multi-Agent AI Blueprint

This architecture is rooted in NIST SP 800-160v2. After analysis of same the following organization of domains and agents was the result.

Multi-Agent Cybersecurity Defensive Ecosystem — Domain Overview

1. **Domain A – Governance, Risk, and Compliance (GRC) & Oversight**
Agents enforce enterprise governance: defining policies, managing risk registers, auditing compliance, collecting signed evidence, monitoring control effectiveness, aggregating metrics, and overseeing supplier risk.
2. **Domain B – Asset, Configuration, and Change Management**
Agents discover assets, enforce configuration baselines, detect drift, govern and approve changes, orchestrate patching, scan for vulnerabilities, and prioritize remediation by risk.
3. **Domain C – Identity, Credential, and Access Management (ICAM)**
Agents manage the identity lifecycle, enforce adaptive authentication policies, control access and privilege, monitor privileged sessions, federate with external IdPs, audit access decisions, and manage cryptographic keys.
4. **Domain D – Threat Intelligence, Situational Awareness, and Monitoring**
Agents aggregate and normalize threat intelligence, correlate SIEM/EDR/cloud data, analyze user and entity behavior (UEBA), conduct proactive threat hunting, map external exposures, and deploy/manage deception assets.
5. **Domain E – Protective Technologies & Hardening**
Agents manage firewall rules, tune IDS/IPS, enforce zero trust segmentation, respond to endpoint threats (EDR), defend against phishing, enforce cloud guardrails, maintain secure baselines, and perform application security scanning.
6. **Domain F – Data Security & Privacy**
Agents discover and classify data, monitor for data loss (DLP), enforce cryptographic protections, securely wipe storage media, monitor data integrity, and apply privacy-enhancing technologies (PETs).
7. **Domain G – Incident Response & Digital Forensics (IR-DFIR)**
Agents triage incidents, automate containment actions, orchestrate recovery

steps, collect and analyze forensic evidence, conduct root-cause analysis, and manage incident communications.

8. Domain H – Resilience, Continuity, and Recovery

Agents create and update continuity plans, orchestrate disaster recovery (DR) procedures, test resilience via chaos engineering, automate failovers with rollback assurance, and maintain immutable, verifiable backups.

9. Domain I – Security Architecture & Systems Engineering (SASE)

Agents advise on secure architecture, orchestrate security systems engineering tasks, design cryptographic architectures, verify secure protocol compliance, curate reusable secure patterns, and enforce DevSecOps pipeline security gates.

10. Domain J – Physical & Environmental Security

Agents control and log physical access, analyze video for anomalies, enforce secure zoning/barriers, monitor OT/ICS systems, and sense environmental conditions (power, HVAC, fire, flood) for impact on HVAs.

11. Domain K – Supply Chain & Lifecycle Security

Agents enforce procurement security requirements, validate authenticity of components, analyze SBOMs for vulnerabilities, and securely manage disposal with tamper-evident chain of custody.

12. Domain L – Security Program Enablement

Agents curate and disseminate institutional security knowledge, compute and report security analytics, orchestrate cross-domain SOAR workflows, curate/label security datasets, and validate AI/ML models for trustworthiness and robustness.

Domain Agents and Coverage of SP 800-160v2 Techniques and Approaches

Following is a breakdown of agents in each domain and which NIST SP 800-160v2 Techniques and Approaches are intended to be addressed by each. Also included is an indicator of the feasibility of automation, where less than Full generally requires a Human-In-The-Loop (HITL) to provide documentation and/or approve or disapprove.

Domain A – GRC & Oversight

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
A1. Governance Policy Agent	Low	Coordinated Defense; Privilege Restriction;	Establish and enforce security policy; Apply approval and exception governance; Update

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
		Adaptive Response	policy sets based on changing conditions
A2. Risk Analysis Agent	Partial	Analytic Monitoring; Realignment; Diversity	Collect and analyze risk indicators continuously; Reprioritize controls as risk context changes; Use multiple independent risk data sources
A3. Compliance Auditor Agent	Partial	Substantiated Integrity; Analytic Monitoring; Transparency	Verify compliance with independent evidence and attestations; Continuously evaluate compliance telemetry against benchmarks; Maintain audit trails for traceability and accountability
A4. Policy Authoring Agent	Partial	Coordinated Defense; Non-Persistence; Adaptive Response	Define enforceable policies consumable by other domains; Time-bound policy exceptions and force re-certification; Incorporate lessons learned and incident feedback into policies
A5. Evidence Collector Agent	Partial	Substantiated Integrity; Diversity; Transparency	Collect cryptographically signed evidence with provenance; Correlate evidence from multiple sources of truth; Publish evidence sets accessible for oversight and audit
A6. Control Monitor Agent	Full	Analytic Monitoring; Coordinated Defense; Adaptive Response	Continuously monitor runtime control effectiveness; Route alerts/events into SOC and IR workflows; Trigger remediation or escalation when control degradation is detected

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
A7. Metrics Aggregator Agent	Full	Analytic Monitoring; Realignment; Transparency	Aggregate and correlate KRIs/KPIs across domains; Adjust governance and risk priorities based on metrics trends; Publish dashboards and reports to executives and auditors
A8. Supplier Risk Agent	Partial	Diversity; Anticipation; Analytic Monitoring	Collect supplier assurance from multiple intel/attestation sources; Detect and analyze emerging supply chain threats; Score and monitor suppliers continuously against policies

Domain B – Asset, Configuration, and Change Management

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
B1. Asset Discovery Agent	Full	Analytic Monitoring; Diversity	Establish and maintain situational awareness of assets; Use multiple discovery sources for accuracy
B2. Baseline Compliance Agent	High	Substantiated Integrity; Coordinated Defense; Analytic Monitoring	Encode security requirements as enforceable configurations; Verify conformance with authoritative baselines; Generate compliance evidence for auditors
B3. Config Monitor Agent	High	Analytic Monitoring; Adaptive Response	Continuously monitor for config drift; Trigger remediation or escalation when drift exceeds thresholds
B4. Change Governance Agent	Partial–High	Privilege Restriction; Coordinated	Enforce dual approvals and SoD for changes; Govern changes with rollback assurance; Time-

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
		Defense; Non-Persistence	bound exceptions and change moratoriums
B5. Patch Orchestration Agent	High	Adaptive Response; Diversity	Automate flaw remediation planning/execution; Validate patching across heterogeneous environments
B6. Vulnerability Scanning Agent	High	Analytic Monitoring; Substantiated Integrity	Perform structured technical verification of vulnerabilities; Collect validated evidence of scans
B7. Risk Prioritization Agent	Partial	Realignment; Analytic Monitoring	Prioritize remediation based on risk scoring; Continuously adjust priorities based on new intel and asset context

Domain C – Identity, Credential, and Access Management (ICAM)

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
C1. Identity Provisioning Agent	High	Substantiated Integrity; Non-Persistence; Adaptive Response	Manage resilient identity lifecycle with cryptographic assurance; Bound account validity with time-based expiration; Adapt identity state based on lifecycle events
C2. Auth Policy Agent	High	Coordinated Defense; Diversity; Adaptive Response	Enforce authentication using multiple signals; Integrate with Zero Trust signal fusion; Dynamically adjust authentication requirements as risk posture changes
C3. Access Control Agent	High	Privilege Restriction; Substantiated Integrity;	Enforce least privilege and SoD; Ensure access policy provenance and rollback; Apply coordinated,

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
		Coordinated Defense	consistent access rules across domains
C4. Privileged Session Monitor Agent	High	Analytic Monitoring; Substantiated Integrity; Transparency	Monitor privileged activity in real time; Verify and log integrity of session evidence; Provide transparent audit of administrator behavior
C5. Identity Federation Agent	High	Diversity; Substantiated Integrity; Adaptive Response	Establish federated trust with multiple IdPs; Assure external identity and key lifecycle; Adapt federation mappings as external providers change
C6. Access Audit Agent	High	Analytic Monitoring; Substantiated Integrity; Realignment	Continuously validate least-privilege and SoD alignment; Generate evidence of access compliance; Adjust policies based on audit results
C7. Crypto Key Manager Agent	High	Substantiated Integrity; Diversity; Adaptive Response	Manage resilient key and certificate lifecycle; Assure issuance/rotation/revocation; Support diversity of cryptographic algorithms and adjust as threats evolve

Domain D – Threat Intelligence, Situational Awareness, and Monitoring

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
D1. Threat Intel Aggregator Agent	High	Diversity; Analytic Monitoring; Adaptive Response;	Correlate multiple intel sources (TAXII/STIX, OSINT, internal sightings); continuously analyze indicators/TTPs; recommend time-bounded COAs

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
		Coordinated Defense	(block/sinkhole/quarantine) with TTL; publish normalized intel for enterprise enforcement
D2. Siem Analyst Agent	High	Analytic Monitoring; Coordinated Defense; Substantiated Integrity	Correlate OTel/EDR/IdP/Cloud logs into ATT&CK-tagged DetectionEvents; route to cases/SOAR; preserve evidence references and mapping for traceability
D3. UEBA Analysis Agent	High	Analytic Monitoring; Adaptive Response; Transparency	Detect identity/device anomalies and emit AuthAnomaly/DetectionEvent; require HITL for human principals/CrownJewels; expose rationale and confidence for auditor transparency
D4. Autonomous Hunter Agent	High	Analytic Monitoring; Realignment; Coordinated Defense	Proactive hypothesis-driven hunts (sandbox-only), pivot and refine based on features/TT Ps; publish HuntNotebook/DetectionEvent and link to IR workflows
D5. Exposure Mapping Agent (ASM)	High	Diversity; Analytic Monitoring; Realignment; Transparency	Correlate DNS/CT, IPAM/BGP/WHOIS, and Cloud inventory to enumerate exposures; score risk hotspots; emit ASMExposure/RiskHotspot and time-series for dashboards; HITL for takedown/control-change actions
D6. Honeypot Controller Agent	High	Deception; Segmentation; Unpredictability; Adaptive Response	Place and rotate decoys/lures per segmentation posture and intel; emit DeceptionEvent; rotate by TTL/campaign velocity; enforce strict access/isolation and HITL for high-risk placements

Domain E – Protective Technologies & Hardening

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
E1. Firewall Policy Agent	High	Coordinated Defense; Segmentation; Substantiated Integrity	Translate intel/incident findings into firewall rules; enforce least privilege flows; simulate blast radius; rollback on adverse effects
E2. IPS Tuning Agent	High	Diversity; Adaptive Response; Analytic Monitoring	Adjust IDS/IPS signatures based on emerging TTPs; reduce false positives via analytics; coordinate detection and prevention across domains
E3. Zero Trust Segmentation Agent	High	Segmentation; Coordinated Defense; Privilege Restriction	Enforce micro-segmentation policies; adapt zone boundaries dynamically; propagate access control decisions across workloads
E4. EDR Response Agent	High	Analytic Monitoring; Adaptive Response; Transparency	Monitor endpoint detections; automate quarantine/block/kill actions with HITL for CrownJewels; provide evidence-linked containment decisions
E5. Phishing Defense Agent	High	Diversity; Deception; Adaptive Response	Analyze email/web artifacts; apply deception (sinkholes, fake lures); coordinate defense across MTA, browser, and identity providers
E6. Cloud Security Agent	High	Substantiated Integrity; Coordinated Defense; Adaptive Response	Continuously enforce cloud guardrails; detect misconfigurations; apply corrective policies aligned with CSPM benchmarks

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
E7. Baseline Enforcement Agent	High	Substantiated Integrity; Privilege Restriction; Adaptive Response	Ensure workload and OS hardening baselines remain enforced; automatically remediate drift; escalate to HITL for sensitive assets
E8. AppSec Scanner Agent	High	Analytic Monitoring; Diversity; Adaptive Response	Perform static/dynamic application security scans; adapt rules based on dev patterns; surface vulnerabilities tied to 800-53 controls

Domain F – Data Security & Privacy

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
F1. Data Discovery Agent	High	Diversity; Analytic Monitoring	Identify and classify information assets; establish context for sensitivity and handling
F2. DLP Monitor Agent	High	Coordinated Defense; Adaptive Response	Detect and prevent data exfiltration; correlate detections and enforce policies; escalate overrides through governance
F3. Crypto Enforcement Agent	High	Substantiated Integrity; Coordinated Defense	Verify and enforce cryptographic protections; monitor key and certificate lifecycle; remediate drift
F4. Secure Wipe Agent	High	Substantiated Integrity; Non-Persistence	Apply NIST 800-88r1 sanitization; validate chain of custody; issue WipeCertificates
F5. Integrity Monitor Agent	High	Substantiated Integrity; Analytic Monitoring	Verify digests and attestations; detect tampering; validate provenance of assets

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
F6. Privacy Enforcement Agent	High	Privilege Restriction; Diversity; Adaptive Response	Enforce PETs (masking, tokenization, DP, k-anonymity); check lawful basis; implement residual risk controls

Domain G – Incident Response & Digital Forensics (IR-DFIR)

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
G1. Incident Triage Agent	High	Analytic Monitoring; Coordinated Defense; Adaptive Response	Correlate multi-source detections (SIEM, UEBA, intel); Prioritize and route incidents by severity and asset criticality; Escalate cases with bounded decision rules and evidence bundles
G2. Automated Containment Agent	High	Adaptive Response; Non-Persistence; Substantiated Integrity	Execute bounded, reversible containment (isolate host, block account); Enforce rollback assurance for failed actions; Require attested evidence before automated blocks/quarantines
G3. Recovery Orchestration Agent	High	Adaptive Response; Realignment; Coordinated Defense	Automate restoration using predefined runbooks; Realign recovery steps with business priorities; Coordinate with continuity/backup agents for data/system reinstatement
G4. Forensic Analysis Agent	Moderate–High	Substantiated Integrity; Diversity; Transparency	Collect forensic artifacts with cryptographic provenance; Correlate across multiple independent data sources (logs, disk, memory); Publish

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
			transparent evidence chains for audit and legal review
G5. RCA Analysis Agent	High	Analytic Monitoring; Realignment; Adaptive Response	Perform structured root-cause analysis using correlated forensic and incident data; Identify systemic control weaknesses; Feed lessons learned into governance and policy updates
G6. Communications Agent	High	Coordinated Defense; Transparency; Adaptive Response	Manage disciplined incident communications; Provide accurate, transparent situational updates to stakeholders; Adjust messaging dynamically as incident state evolves

Domain H – Resilience, Continuity, and Recovery

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
H1. Continuity Planning Agent	High	Coordinated Defense; Realignment; Transparency	Generate and maintain continuity plans mapped to critical assets; Trace dependencies and risks across domains; Provide transparent dashboards for governance and audit
H2. DR Orchestration Agent	High	Adaptive Response; Substantiated Integrity; Coordinated Defense	Automate disaster recovery runbooks; Execute bounded and reversible restoration actions; Ensure provenance and validation of failover results; Coordinate recovery with business priorities

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
H3. Resilience Engineering Agent	High	Diversity; Adaptive Response; Realignment; Unpredictability	Conduct chaos/fault injection experiments; Exercise graceful degradation and recovery modes; Validate self-healing and rollback mechanisms; Adjust resilience guardrails based on test outcomes
H4. Failover Automation Agent	High	Adaptive Response; Substantiated Integrity; Analytic Monitoring	Automate failover using canary-first methods; Continuously monitor quorum and readiness; Provide rollback assurance and traceability for transitions; Validate failover against RTO/RPO thresholds
H5. Immutable Backup Agent	High	Substantiated Integrity; Diversity; Coordinated Defense	Store backups in tamper-resistant immutable storage; Apply cryptographic attestation to snapshots; Regularly test restoration to ensure integrity and compliance with continuity objectives

Domain I – Security Architecture & Systems Engineering (SASE)

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
I1. Architecture Advisor Agent	Partial–High	Coordinated Defense; Realignment; Transparency	Apply security design patterns across systems; Continuously align architecture with evolving threats; Provide transparent traceability of design decisions
I2. SSE Process Agent	Partial–High	Coordinated Defense; Analytic Monitoring;	Orchestrate SSE lifecycle tasks with embedded security; Monitor design and implementation readiness;

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
		Adaptive Response	Adjust engineering gates dynamically based on control evidence
I3. Crypto Architecture Agent	Partial–High	Substantiated Integrity; Diversity; Coordinated Defense	Engineer layered cryptographic protections; Ensure provenance and integrity of crypto mechanisms; Use diverse cryptographic algorithms and key hierarchies to withstand compromise
I4. Protocol Compliance Agent	High	Substantiated Integrity; Analytic Monitoring; Transparency	Continuously verify security protocols against standards; Monitor conformance and detect deviations; Provide evidence of compliance for audit
I5. Pattern Management Agent	High	Coordinated Defense; Diversity; Realignment	Develop and curate secure architecture patterns; Apply patterns across multiple systems for consistency; Retire or realign patterns as threats and standards evolve
I6. DevSecOps Pipeline Agent	High	Analytic Monitoring; Adaptive Response; Substantiated Integrity	Automate security gates in CI/CD pipelines; Monitor and correlate SAST/DAST/IaC/SCA results; Enforce provenance and attested evidence before promotion to production

Domain J – Physical & Environmental Security

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
J1. Physical Access Agent	High	Privilege Restriction;	Enforce least-privilege physical access; Apply dual approval for

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
		Coordinated Defense; Substantiated Integrity	high-sensitivity areas; Bind physical entry events to cryptographically signed logs
J2. Video Analytics Agent	High	Analytic Monitoring; Diversity; Transparency	Continuously monitor video feeds for anomalies; Fuse multiple analytic sources (motion, biometrics, thermal); Provide transparent evidence packages for investigators
J3. Facilities Security Agent	High	Segmentation; Coordinated Defense; Realignment	Define and enforce secure zones/barriers; Coordinate zoning with logical ICAM policies; Realign facility plans as risk posture or layout changes
J4. OT Monitoring Agent	High	Analytic Monitoring; Adaptive Response; Diversity	Continuously monitor ICS/SCADA telemetry for unsafe states; Detect protocol misuse across diverse sensors; Trigger bounded containment responses
J5. Environmental Monitor Agent	High	Analytic Monitoring; Anticipation; Adaptive Response	Continuously sense environmental conditions (power, HVAC, fire); Anticipate degradation that could impact system resilience; Alert and coordinate adaptive recovery actions

Domain K – Supply Chain & Lifecycle Security

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
K1. Procurement Policy Agent	High	Coordinated Defense; Realignment; Privilege Restriction	Enforce security requirements in supplier contracts; Gate procurement with SBOM/SLSA checks; Realign sourcing policies as risks and standards evolve
K2. Authenticity Verification Agent	High	Substantiated Integrity; Diversity; Transparency	Validate component authenticity via multi-source evidence (certs, hashes, attestations); Apply diverse verification paths (CRL, OCSP, Rekor); Provide transparent audit trails for authenticity reports
K3. SBOM Analysis Agent	High	Analytic Monitoring; Adaptive Response; Substantiated Integrity	Continuously analyze SBOMs for vulnerabilities; Adapt remediation priorities using KEV/EPSS; Ensure provenance and integrity of SBOM data
K4. Secure Disposal Agent	High	Segmentation; Anticipation; Substantiated Integrity	Segment and control the disposal workflow with chain-of-custody; Anticipate risks from legal holds and custody breaks; Provide signed, tamper-evident Disposal Certificates

Domain L – Security Program Enablement

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
L1. Security Knowledge Agent	High	Diversity; Transparency; Realignment	Aggregate knowledge from multiple sources (playbooks, RCAs, threat intel); Provide transparent taxonomies for reuse; Continuously evolve

Agent	Automation Feasibility	800-160v2 Techniques	800-160v2 Approaches
			security knowledge as conditions change
L2. Security Analytics Agent	High	Analytic Monitoring; Realignment; Adaptive Response	Continuously measure security KPIs/KRIs; Detect outliers and anomalous patterns; Adjust governance and priorities based on analytic trends
L3. SOAR Orchestration Agent	High	Coordinated Defense; Adaptive Response; Substantiated Integrity	Orchestrate incident workflows across domains; Execute bounded automated responses with rollback paths; Preserve provenance of orchestration actions for audit
L4. Data Curation Agent	High	Diversity; Substantiated Integrity; Transparency	Curate datasets from diverse sources for AI/analytics; Enforce provenance and integrity of curated data; Provide transparent labeling and lineage for governance
L5. AI Validation Agent	High	Substantiated Integrity; Diversity; Realignment	Validate AI/ML outputs with signed evidence and test oracles; Apply diverse validation methods (robustness, fairness, adversarial tests); Adjust AI acceptance thresholds as risks evolve

Building an AI Agent with Examples

What follows is not intended to teach you how to build an AI agent, generally. This is an overview of what goes into building an agent for our purposes.

AI for Cybersecurity Staff

Bridging GRC Program Oversight with AI Agent Implementation

1. What is MCP?

- **Think of it as an envelope.**
Every agent message is wrapped with metadata:
 - mission_id, role, intent, policy_refs, decision_basis, provenance, classification, legal_hold
 - **Why you care:** This guarantees traceability, auditability, and enforceable constraints — every action is explainable.
-

2. Deterministic vs. AI/LLM

- **Deterministic:** Rules, formulas, thresholds (e.g., risk scoring math). Predictable and testable.
 - **LLM:** Used only for parsing, classifying, summarizing, or judgment when rules aren't enough.
 - **Why you care:** You know exactly which decisions are *verifiable math* vs. *probabilistic AI*.
-

3. HITL (Human-in-the-Loop) & Constraints

- **HITL = Stop Sign.** Agent pauses and waits for a human signature before proceeding.
 - **Constraints:** Flags like policy_cosign, auto_open_ticket, or legal_hold are machine-enforced.
 - **Why you care:** You set the rules (what needs HITL, what doesn't). The system enforces them reliably.
-

4. Schema Contracts = Fixed Audit Forms

- Inputs/outputs follow a schema (like a form).
- If the schema changes, consumers must test/approve before rollout.

- **Why you care:** Prevents silent drift in audit reports — consistency across time.
-

5. Provenance & Attestations

- Every agent output is **digitally signed**.
 - Attestations (like SLSA) prove: *what code built this, when, and on which inputs*.
 - **Why you care:** This is your tamper-proof chain of custody — auditors can trust the evidence.
-

6. Lifecycle of an Agent

- **Stages:** Local test → Container → CI/CD → Canary → Production.
 - **Why you care:**
 - You'll be asked to **approve formulas, schemas, or registry entries**.
 - You'll review SLOs during canary rollouts.
 - You'll sign off when guardrails (HITL, sovereignty, classification) are satisfied.
-

7. Your Role in Governance (RACI view)

- **Responsible:** Define HITL rules, data classification tiers, evidence sufficiency, risk thresholds.
 - **Accountable:** Approve schema registry entries, formula changes, policy control mappings.
 - **Consulted:** Rollout reviews (canary metrics, policy cosigns).
 - **Informed:** Dashboards, incident reports, deployment status.
-

8. Before vs. After Example

- **Before:** Analyst manually reviews change tickets, matches evidence to AU-12, fills Excel, emails auditor.
- **After:** EvidenceCollector agent auto-generates ComplianceGap with control_id + evidence_ref. Auditor just verifies signatures.

- **Why you care:** Your oversight shifts from **manual checking** to **approving rules & reviewing dashboards**.
-

✅ **Bottom Line for Cybersecurity Staff:**

- MCP = **structured control wrapper** (not AI magic).
 - HITL/constraints are **machine-enforced guardrails**, not optional.
 - Provenance/attestation = **tamper-proof audit logs**.
 - Your job shifts from checking individual tickets to **setting rules, approving changes, and monitoring trust metrics**.
-

How an AI Agent is Built – With Examples

Section 1 — What’s an “AI agent,” in plain English

An AI agent is a small software worker that:

1. listens for events (inputs),
2. decides something using rules + an LLM, and
3. sends structured outputs to the rest of your stack.

Think of it like a bot that lives between your tools (GitHub, SIEM, Jira, etc.) and your policies, with guardrails so it can’t go rogue. Your example file shows several such workers (Policy Authoring, Risk Analysis, Compliance Auditor, Evidence Collector, etc.), each with clearly defined inputs, decisions, and outputs.

Section 2 — The 7 building blocks (the “minimum viable agent” kit)

Use these seven pieces no matter which agent you build:

1. Identity & provenance
 - Give the agent a strong identity and sign what it emits (SPIFFE/SPIRE ID + key ID).
 - Why: downstream systems can verify “this really came from our agent.”
2. Contracted inputs
 - Define exactly which native protocols it consumes (e.g., GitHub webhook JSON, SIEM events, CMDB records).

- Tip: keep example payloads handy; your doc shows native JSON + “wrapped” versions.
3. MCP context wrapper (your blueprint’s secret sauce)
 - Every message carries a small “context header” with fields like: mission_id, role, intent, policy_refs, decision_basis (evidence_refs, confidence), classification, legal_hold, provenance.attestation, constraints (e.g., policy_cosign).
 - That one envelope makes routing, auditing, and enforcement testable.
 4. Decision logic (deterministic first, LLM second)
 - Start with math/rules, then ask the LLM to help with edge cases and phrasing.
 - Example formulas you can reuse:
 - $\text{change_impact_score} = 0.4\text{blast_radius} + 0.3\text{control_criticality} + 0.2*(1 - \text{evidence_confidence}) + 0.1*\text{churn_rate}$
 - $\text{risk_score} = w_sevsev + w_exposureexposure + w_exploitexploit + w_impactimpact$ with w’s summing to 1.0
 - Use HITL (human-in-the-loop) gates for anything touching “Crown Jewels.”
 5. Output contracts (OCs)
 - Treat outputs like APIs with schemas + idempotency keys + ACK/NACK behavior (e.g., “PolicyBundlePublish”, “RiskAssessment”, “ComplianceGap”, “ControlStatus”).
 - Downstream services must be able to validate version ranges and signatures.
 6. Guardrails & safety
 - Path allowlists, scope-limited tokens, classification labels (C1–C3), legal_hold, rate limits, and a kill_switch.
 7. States, SLOs, and testing
 - Model each agent as a small state machine (idle → processing → publishing → failed → closed).
 - Define p95 ACK targets (e.g., ≤ 30–60 s), false-positive ceilings, and rollback rules.
 - Ship contract tests and offline replays.

Section 3 — A copy-paste template you can adapt in any stack

Below is a minimal “hello-agent” pattern you can implement with your favorite framework (FastAPI/Express) and any LLM. It mirrors the structure in your file (inputs → MCP context → decisions → output contracts).

3A) Message “envelope” (MCP-style context)

Use this for every inbound/outbound message:

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "<uuid-or-incident-id>",
    "thread_id": "<source-record-or-pr-id>",
    "task_id": "<uuid-step>",
    "role": "<AgentName>",
    "intent": "<govern|collect|measure|monitor>",
    "policy_refs": ["<e.g., AU-12>", "<CM-6>"],
    "constraints": ["<e.g., policy_cosign>", "<auto_open_ticket>"],
    "decision_basis": {
      "evidence_refs": ["uri://..."],
      "confidence": 0.90,
      "explanation_ref": "uri://kb/..."
    },
    "provenance": {
      "producer_spiffe": "spiffe://org/security/<agent>",
      "signing_kid": "kid-<agent>-01",
      "attestation_ref": "uri://slsa/attestations/<agent>@sha256:<digest>"
    },
    "classification": "C2",
    "legal_hold": false
  },
}
```

```
"native_payload": { /* the original webhook/event */ }  
}
```

Why this matters:

- uniform auditing and verification;
- versioning and compatibility checks;
- consistent decision trails across all agents.

3B) The 10-step implementation checklist

1. Define the agent's "Purpose" in one sentence.
2. List authoritative inputs and add one JSON example per input.
3. Design your MCP context (fields above).
4. Write deterministic rules and formulas first; specify HITL triggers.
5. Choose 1–2 Output Contracts with clear schemas and idempotency keys.
6. Add guardrails: allowlists, token scopes, classification, legal_hold.
7. Model a tiny state machine + timeouts/retries.
8. Add SLOs/KPIs (e.g., Ack_p95 <= 30 s; FalseAlertRate_30d <= 1 percent).
9. Implement contract tests + offline replays.
10. Sign outputs and verify signatures on the consumer side.

Section 4 — Worked Examples

Now let's walk through two agents from your document to make the abstract concrete. These are simplified, but still structured so you can lift and use them.

4A) Example 1: Risk Analysis Agent

Purpose: Convert system change inputs into a standardized risk score.

Inputs (authoritative sources):

- Change requests (ServiceNow/Jira tickets).
- Vulnerability scanner findings.
- Threat intel feed snippets.

MCP context additions:

- intent: "measure"
- policy_refs: ["RA-5", "CM-3"]
- constraints: ["auto_open_ticket", "policy_cosign"]

Decision logic:

- Formula (deterministic first):
$$\text{risk_score} = 0.4 \cdot \text{sev} + 0.3 \cdot \text{exposure} + 0.2 \cdot \text{exploit} + 0.1 \cdot \text{impact}$$
- Add LLM assist to classify narrative descriptions ("likely exploitation scenario" vs "low interest").
- Human-in-the-loop: require approval if risk_score > 0.7.

Outputs (contracts):

- RiskAssessment (schema includes idempotency_key, risk_score, explanation_ref).
- Status: Ack/Nack with error details.

Guardrails:

- Classification defaults to C2.
- No external calls except allowlisted threat feeds.
- Legal_hold enforced if incident category = "investigation."

4B) Example 2: Compliance Auditor Agent

Purpose: Check evidence against control requirements, flag gaps.

Inputs:

- Control library (NIST 800-53, ISO 27002).
- Evidence packages (logs, CMDB snapshots).
- Prior audit results.

MCP context additions:

- intent: "govern"
- policy_refs: ["AU-12", "CA-2"]

- constraints: ["policy_cosign", "HITL_on_gap_detected"]

Decision logic:

- Deterministic: evidence completeness check (all required artifacts present?).
- LLM assist: semantic match between evidence text and control description.
- Formula: $\text{compliance_gap_score} = (\text{missing_controls} / \text{total_controls}) * 100$.

Outputs:

- ComplianceGap contract (schema: {gap_id, control_id, evidence_refs, explanation_ref}).
- Signed bundle for downstream audit systems.

Guardrails:

- Enforced human signoff for gaps > 20%.
- Logging of every decision basis.
- Provenance signature on each ComplianceGap record.

Section 5 — Guardrails & HITL Patterns

Think of safety as layered defenses:

Do:

- Use **constraints in MCP context** (policy_cosign, auto_open_ticket, HITL_on_gap_detected).
- Apply **classification tags** (C1–C3) to block sensitive data from leaking.
- Implement a **kill_switch** for runtime halt.
- Always **sign outputs** and enforce signature verification downstream.
- Use **rate limits** to stop runaway loops.

Don't:

- Let agents auto-deploy without HITL gates.
- Mix authoritative sources with unverified free-text feeds.
- Allow cross-domain writes (e.g., ticket agent writing configs) without strict scoping.

- Skip provenance—auditors will reject unsigned evidence.
-

Section 6 — Testing & Rollout

1. **Contract tests:** Validate MCP context and output contract schemas.
 2. **Replay harness:** Feed last quarter's events to simulate agent runs.
 3. **SLOs to enforce:**
 - Ack_p95 <= 60s
 - FalseAlertRate_30d <= 1%
 - Coverage >= 95% of known events.
 4. **Rollout pattern:**
 - Stage → Shadow (agent observes but doesn't act) → Controlled (HITL gating) → Full auto.
-

Section 7 — Minimal Code Skeleton

Here's a stripped Python example to show how all this ties together:

```
from fastapi import FastAPI, Request
```

```
import uuid, time, hmac, hashlib
```

```
app = FastAPI()
```

```
def sign_payload(payload: dict, secret: str) -> str:
```

```
    return hmac.new(secret.encode(), str(payload).encode(), hashlib.sha256).hexdigest()
```

```
@app.post("/agent/risk")
```

```
async def risk_agent(request: Request):
```

```
    native = await request.json()
```

```
    mission_id = str(uuid.uuid4())
```

```
mcp_context = {
    "mcp_version": "0.9",
    "mission_id": mission_id,
    "role": "RiskAnalysisAgent",
    "intent": "measure",
    "policy_refs": ["RA-5", "CM-3"],
    "decision_basis": {"evidence_refs": ["ticket123"], "confidence": 0.9},
    "provenance": {"producer_spiffe": "spiffe://org/security/riskagent"},
    "classification": "C2",
    "legal_hold": False
}
```

Simplified deterministic formula

```
sev, exposure, exploit, impact = 0.7, 0.5, 0.4, 0.6
```

```
risk_score = 0.4*sev + 0.3*exposure + 0.2*exploit + 0.1*impact
```

```
output_contract = {
    "type": "RiskAssessment",
    "idempotency_key": mission_id,
    "risk_score": risk_score,
    "mcp_context": mcp_context
}
```

```
output_contract["signature"] = sign_payload(output_contract, secret="my-secret-key")
```

```
return output_contract
```

This small service:

- Accepts inputs → wraps them in MCP context → applies a formula → emits a signed contract.

Cybersecurity Context for AI Developers

Bridging MCP + GRC Program Needs

1. Policy & Control Framework Map

What's required: Agents must tag decisions with the right compliance controls.

- **Examples:**
 - **Risk Analysis Agent** → RA-5 (Vulnerability Management), CM-3 (Change Control)
 - **Compliance Auditor Agent** → AU-12 (Audit Logging), CA-2 (Assessments)
 - **Developer takeaway:** Always fill `mcp_context.policy_refs` — this ties your outputs back to the control framework.
-

2. Decision Authority & HITL Rules

When to stop & ask a human:

- **Auto-only:** Low severity findings (`risk_score < 0.3`).
 - **HITL required:**
 - Any “Crown Jewels” asset touched
 - `risk_score > 0.7`
 - Supplier reclassification
 - **Developer takeaway:** Build HITL tokens/co-sign constraints (constraints: `["policy_cosign"]`) into your MCP context.
-

3. Data Classification & Sovereignty

Tiered handling rules:

- **C1:** Public (policies, patch notes) – can flow anywhere.
- **C2:** Internal (tickets, control evidence) – restricted routing.
- **C3:** Restricted (incident forensics, `legal_hold`) – redacted or encrypted; legal holds apply.

- **Developer takeaway:** Always populate classification in MCP context; block C3 data from non-approved outputs.
-

4. Evidence & Audit Expectations

Every decision must be provable.

- **EvidenceManifest fields:**
 - evidence_refs (URI + SHA-256)
 - timestamps (collected_at, attested_at)
 - attestation_ref (supply-chain or provenance doc)
 - **Developer takeaway:** Never just “log text” — structure and sign all evidence.
-

5. Change Control & Governance

Rules for changing agent logic:

- **Formulas/thresholds:** HITL review + version bump.
 - **Output Contract schemas:** Must go through schema registry, with consumer compatibility tests.
 - **Developer takeaway:** Treat formulas and schemas like APIs — version, test, and register before rollout.
-

6. Metrics & SLOs That Matter

- **Ack_p95 $\leq 60s$** → audit logs must be timely.
 - **FalseAlertRate $\leq 1\%$** → auditors need low noise.
 - **GapDetectionLatency ≤ 5 min** → gaps must be flagged fast.
 - **Developer takeaway:** Optimize for *audit trust metrics*, not just throughput/latency.
-

7. The “Why This Exists” Story

- **Risk Analysis Agent:** reduces unreviewed risky changes by scoring tickets automatically.

- **Compliance Auditor Agent:** prevents failed audits by checking evidence packages upfront.
- **Developer takeaway:** These agents are not just “smart bots” — they cut audit prep time, reduce risk exposure, and protect regulatory posture.

Quick Reference MCP Fields

```
mcp_context: {  
  mission_id, role, intent, policy_refs,  
  constraints, decision_basis, provenance,  
  classification, legal_hold  
}
```

Developer takeaway: Every input and output *must* be wrapped with this envelope.

✓ Bottom line for developers:

- Always **wrap messages with MCP context**.
- Always **attach evidence and provenance**.
- Always **enforce HITL & classification rules**.
- Always **measure against the GRC-specific SLOs**.

High-Level Development and Deployment Guide

This section presents a high-level, step-by-step deployment walkthrough (local test → containerization → CI/CD), aligned with the agent blueprint and MCP-style contracts introduced earlier. The emphasis is on implementation checklists rather than source code.

1) Local development & test (single developer loop)

Goal: Prove the agent’s behavior against its **input contracts**, **MCP context**, and **output contracts**, all on your laptop.

1. Define scope & contracts
 - Pick the one agent you’ll ship first (e.g., Risk Analysis or Compliance Auditor).

- Freeze the input payload examples and the **MCP context fields** your agent must accept/emit (mission_id, role, intent, policy_refs, decision_basis, provenance, classification, legal_hold).
- 2. Build a tiny replay harness
 - Use ~10–50 realistic sample payloads (JSON) per input type; include corner cases and NACK paths (bad schema, missing evidence).
 - Replay them locally; assert **Ack/Nack windows** and **idempotency**. Example targets exist in your doc (ack<=30s, exp-backoff<=5x).
- 3. Validate “deterministic first”
 - Lock in formula outputs and rule decisions without an LLM; compare to expected RiskAssessment/ComplianceGap samples.
- 4. Dry-run guardrails
 - Confirm read-only on sources and limited write scopes (ticket/GRC only), classification labels (C1–C3), and legal_hold toggles.
- 5. Record provenance
 - Even locally, attach a dummy **provenance** block (producer_spiffe, signing_kid, attestation_ref) to outputs so downstream verifiers are exercised later.

Exit criteria:

- 95%+ of replays produce the expected Output Contracts (e.g., RiskAssessment, ComplianceGap) with valid **MCP context** and **provenance**.

2) Containerize (portable, policy-enforced runtime)

Goal: Package the agent so the same thing runs everywhere, with supply-chain attestations.

1. Create a minimal container image
 - Include only the runtime + your agent; keep tools out.
 - Generate **SBOM** and **SLSA/in-toto** attestations as build artifacts and plan to **sign all outputs** at runtime.
2. Externalize configuration
 - Inputs (endpoints, topics), thresholds, and weight tables must be config, not code; version them separately and plan canary updates.

3. Wire secrets & scopes

- Mount short-lived credentials with minimum scopes (e.g., read-only SIEM/CMDB; write-only GRC/ticket). Guardrails from the doc should be enforced by token scopes and allowlists.

4. Bake in health & telemetry

- Expose /healthz and structured logs with **trace_id**, **mission_id**, **policy_refs**, **evidence_refs** so end-to-end tracing works in staging.

Exit criteria:

- Image published with SBOM + attestation; config and secrets injected at run; health/telemetry verified in a local container.

3) Staging environment (shadow then gated actions)

Goal: Exercise end-to-end flows with real integrations but **no production side-effects** at first.

1. Deploy in **Shadow Mode**

- Subscribe to real feeds; **emit outputs to a staging bus** and a “black-hole” GRC/ticket endpoint; compare decisions to manual baselines.
- Verify **state machine** transitions (idle → ingesting → evaluating → emitting_gap → awaiting_hitl → ...).

2. Turn on **gated actions (HITL)**

- Enable writes to real ticket/GRC but force **HITL tokens** for any destructive or sensitive downgrades (e.g., accept-risk above threshold; Crown Jewels severity changes).

3. Test Output Contracts & registries

- Register schemas and verify **version ranges/EOL** in the schema registry before consumers accept messages.

4. Negative & adversarial tests

- Tampered attestations, stale timestamps, doctored SBOMs should fail closed or require HITL—this is called out explicitly in your doc’s testing guidance.

Exit criteria:

- Shadow accuracy within tolerance; HITL workflows exercised; schema registry compatibility passes.
-

4) Observability & evidence (make auditors happy)

Goal: Ensure every decision is explainable, signed, and reconstructible.

1. Decision transparency
 - Require `decision_basis` with `evidence_refs`, `confidence`, and `explanation_ref` for every actionable output; `surface_classification_label` and `provenance.attestation` in UIs.
2. Evidence chain
 - Emit **EvidenceManifest** (URLs + SHA-256 + timestamps), with content-addressing and signatures; enforce monotonic audit-chain append.
3. SLOs & KPIs
 - Start from the blueprint's targets (e.g., `GapDetectionLatency_p95` $\leq$ 5 min; `FalseGapRate_30d` $\leq$ 1 percent) and publish them to dashboards.

Exit criteria:

- Dashboards show SLO burn; every output points to its evidence and rationale; signatures validate.
-

5) CI pipeline (build-time trust)

Goal: Make builds reproducible and policy-checked before deployment.

1. Stages
 - **Lint/Schema:** validate MCP context fields and Output Contracts schemas.
 - **Unit/Replay:** run deterministic tests and dataset replays.
 - **Security:** SAST, dependency scanning, SBOM diff.
 - **Provenance:** generate SLSA/in-toto attestations; sign the image.
2. Gates
 - Fail the build if schema drift, missing `decision_basis` fields, or unsigned artifacts.
3. Artifacts

- Publish: container image, SBOM, attestation, contract schemas, and sample outputs for consumer contract tests.

Exit criteria:

- A signed, attestable image + bundle is produced with validated contracts and test reports.
-

6) CD pipeline (progressive delivery with guardrails)

Goal: Move from staging → canary → production with automatic rollbacks.

1. Canary with policy gates
 - Route a small percentage of traffic or a subset of topics (by asset scope or control_id) to the new version; **consumers must verify co-sign and constraint flags** (e.g., policy_cosign) before honoring sensitive actions.
2. HITL & sovereignty enforcement
 - Production enforcers must reject actions without valid co-signs; procurement/API gateways must enforce **region/sovereignty constraints** when Supplier Risk decisions are involved.
3. Automatic rollback rules
 - Roll back on SLO breach (Ack_p95, FalseAlertRate), schema validation failures, or signature/attestation validation errors.
4. Versioning & EOL
 - Track producer/consumer compatibility and **EOL dates** via the schema registry; block deploys that would break declared ranges.

Exit criteria:

- Canary passes KPIs and policy checks; promotion is automatic; rollback is proven.
-

7) Operations, runbooks, and change control

Goal: Keep day-2 operations boring and auditable.

1. Runbooks
 - Incident runbooks for NACK storms, schema registry errors, HITL queue backups, or sovereignty policy conflicts.

2. Controlled changes

- Treat formula or threshold changes like code: sign a **FormulaChange** request (HITL), canary, then roll out.

3. Lifecycle hygiene

- Keep a release SBOM, publish SLSA attestations, and sign all outputs for each release.

One-page pre-prod checklist (use before the first prod push)

- Input examples frozen; MCP context fields present; schemas registered (accepted ranges/EOL).
- Output Contracts validated (ComplianceGap/RiskAssessment/EvidenceManifest) with idempotency and ACK targets.
- Guardrails enforced: read-only sources, scoped writes, classification, legal_hold, policy_cosign where applicable.
- Provenance and signatures verified by consumers; attestation checks pass.
- SLO dashboards green (GapDetectionLatency, FalseAlertRate, ACK windows).
- Canary + rollback rules configured; co-sign/HITL enforced on sensitive actions.

How the Domains Interconnect

- **Governance, Risk, and Compliance (Domain A)**
Sets the policy backbone for *all other domains*. Every agent (baseline, ICAM, IR, supply chain, etc.) emits evidence that flows back into GRC dashboards and POA&M tracking.
- **Asset, Config, and Change Management (Domain B)**
Feeds inventory, baselines, and drift data to **Incident Mgmt (G)**, **Monitoring (D)**, **Supply Chain (K)**, and **Continuity (H)**.
- **Identity, Credential, and Access Mgmt (Domain C)**
Provides authZ/authN context to all other domains — e.g., IR (G) needs user IDs, Monitoring (D) correlates logins, Network (I/E) enforces access policies.
- **Threat Intel, Situational Awareness, Monitoring (Domain D)**
Collects telemetry from **every other domain** (B for config drift, F for data access, J for physical anomalies, etc.). Its detections drive **IR (G)**.

- **Protective Technologies & Hardening (Domain E)**
Deploys host/network/app defenses that are enforced and validated by **Baseline Compliance (B)** and monitored by **D**.
- **Data Security & Privacy (Domain F)**
Ties directly into ICAM (C) for access enforcement, Monitoring (D) for audit, and Continuity (H) for backup/encryption requirements.
- **Incident Response & Forensics (Domain G)**
Consumes findings from **every domain** (Monitoring, Baseline, IAM, Supply Chain) to drive triage, analysis, and lessons learned into **L (Enablement)**.
- **Resilience, Continuity, Recovery (Domain H)**
Depends on **B (asset inventories)**, **F (data classification)**, **K (supply chain)** for continuity plans and failovers.
- **Security Architecture & Systems Engineering (Domain I)**
Provides segmentation, trust zones, and design standards that all other domains operate within.
- **Physical & Environmental Security (Domain J)**
Feeds access logs into **Monitoring (D)**, connects to **ICAM (C)** for logical/physical identity correlation, supports **Continuity (H)**.
- **Supply Chain & Lifecycle Security (Domain K)**
Ingests software/hardware inventories from **B**, enforces procurement policy feeding into **GRC (A)** and **Risk Mgmt (A)**.
- **Security Program Enablement (Domain L)**
Curates the knowledge from *all domains* (IR RCAs, Monitoring alerts, Baseline drift, Threat Intel) to train personnel and improve policy.

Manual Document Inputs and Outputs

Domain A – Governance, Risk & Compliance (GRC)

- **A1 Governance Policy Agent**
 - Manual docs: Draft policy PRs, control evidence packages.
 - Outputs: Policy bundles (OPA/OCI), co-sign decisions, rubric feedback comments, compliance tickets.
- **A2 Risk Analysis Agent**
 - Manual docs: Risk register entries, threat models.
 - Outputs: Risk priority reports, RiskScore annotations, remediation priority queues.

- **A3 Compliance Auditor Agent**
 - Manual docs: Audit frameworks (NIST, ISO mappings), compliance control checklists.
 - Outputs: ComplianceAuditReports, audit dashboards, evidence gap tickets.
 - **A4 Policy Authoring Agent**
 - Manual docs: Regulatory updates, new standards/framework documents.
 - Outputs: Policy drafts (Markdown/YAML), proposed control mappings, PRs.
 - **A5 Evidence Collector Agent**
 - Manual docs: Evidence manifests (linked artifacts from SIEM, configs, etc.).
 - Outputs: Evidence bundles, EvidenceManifests, reports stored in Evidence Registry.
 - **A6 Control Monitor Agent**
 - Manual docs: Baseline control definitions, mappings to standards.
 - Outputs: ControlStatus alerts, metrics dashboards.
 - **A7 Metrics Aggregator Agent**
 - Manual docs: KPIs/KRIs definition docs.
 - Outputs: MetricSnapshots, governance dashboards, exec reports.
 - **A8 Supplier Risk Agent**
 - Manual docs: Vendor security questionnaires, attestations, SBOMs.
 - Outputs: SupplierRiskScores, IntegrationPolicy decisions, risk reports.
-

Domain B – Asset, Configuration & Change Management

- **B1 Asset Discovery Agent**
 - Manual docs: Scan exceptions, OT/IoT classification overrides.
 - Outputs: AssetRecords in CMDB, AssetDiscoveryEvents, exposure reports.
- **B2 Baseline Compliance Agent**
 - Manual docs: Baseline standards, config templates.
 - Outputs: ComplianceDrift reports, dashboards, baseline deviation alerts.
- **B3 Config Monitor Agent**
 - Manual docs: Config baselines, OU/site mappings.
 - Outputs: DriftAlerts, Change PRs, tickets.
- **B4 Change Governance Agent**
 - Manual docs: CAB approval forms, governance change policies.
 - Outputs: ChangeDecision logs, approval records.

- **B5 Patch Orchestration Agent**
 - Manual docs: Patch windows, maintenance approvals.
 - Outputs: Patch rollout plans, PatchOutcome reports.
 - **B6 Vulnerability Scanning Agent**
 - Manual docs: Approved scan scopes, exclusion lists.
 - Outputs: VulnFindings, Vulnerability Reports.
 - **B7 Risk Prioritization Agent**
 - Manual docs: Business impact/risk weightings.
 - Outputs: RemediationQueue, RiskPriority reports.
-

Domain C – ICAM

- **C1 Identity Provisioning Agent**
 - Manual docs: HRIS updates (joiner/mover/leaver).
 - Outputs: AccessChange events, provisioning logs.
 - **C2 Auth Policy Agent**
 - Manual docs: Authentication/UEBA policy rules.
 - Outputs: AuthDecision events, anomaly alerts.
 - **C3 Access Control Agent**
 - Manual docs: Role catalogs, entitlement policies.
 - Outputs: Policy bundles to PDP/PEP, access enforcement logs.
 - **C4 Privileged Session Monitor Agent**
 - Manual docs: PAM session approvals, escalation notes.
 - Outputs: PrivilegedAnomaly reports, session transcripts, alerts.
 - **C5 Identity Federation Agent**
 - Manual docs: Federation agreements, SAML/OIDC metadata.
 - Outputs: TrustChange alerts, federation configs.
 - **C6 Access Audit Agent**
 - Manual docs: SoD policies, entitlement review records.
 - Outputs: SoDViolation reports, AccessReview dashboards.
 - **C7 Crypto Key Manager Agent**
 - Manual docs: CSR submissions, key lifecycle policies.
 - Outputs: Certificates, KeyRotation reports, TrustStore updates.
-

Domain D – Threat Intelligence & Monitoring

- **D1 Threat Intel Aggregator**
 - Manual docs: External CTI feeds (STIX/TAXII), OSINT intel reports.
 - Outputs: IntelIOC events, COA recommendations, threat reports.
 - **D2 SIEM Analyst**
 - Manual docs: Detection rule catalogs, tuning guides.
 - Outputs: DetectionEvents, dashboards, alerts.
 - **D3 UEBA Analysis**
 - Manual docs: Behavior models, risk scoring rules.
 - Outputs: UEBA risk scores, anomaly reports.
 - **D4 Autonomous Hunter**
 - Manual docs: Hunt hypotheses, playbooks.
 - Outputs: HuntFindings, prioritized exposure reports.
 - **D5 Exposure Mapping (ASM)**
 - Manual docs: Asset classification, attack surface catalogs.
 - Outputs: ExposureRecords, RiskHotspots, reports.
 - **D6 Honeypot Controller**
 - Manual docs: Honeypot deployment configs.
 - Outputs: DeceptionEvents, attack telemetry reports.
-

Domain E – Protective Technologies

- **E1 Firewall Policy Agent**
 - Manual docs: Change window approvals, CAB forms.
 - Outputs: FWRuleChange records, RuleAuditResults.
- **E2 IPS Tuning Agent**
 - Manual docs: False positive adjudications.
 - Outputs: TuningPlans, IPS policy updates.
- **E3 Zero Trust Segmentation Agent**
 - Manual docs: Zone definitions, segmentation plans.
 - Outputs: Segmentation policies, PolicyDispute reports.
- **E4 EDR Response Agent**
 - Manual docs: Break-glass approvals.
 - Outputs: EDRActionOutcome reports, block/quarantine logs.
- **E5 Phishing Defense Agent**
 - Manual docs: Phishing playbooks, escalation docs.
 - Outputs: MaliciousAttachmentReports, awareness dashboards.

- **E6 Cloud Security Agent**
 - Manual docs: Guardrail definitions, policy configs.
 - Outputs: GuardrailEnforcement reports, violation alerts.
 - **E7 Baseline Enforcement Agent**
 - Manual docs: Baseline control docs.
 - Outputs: Enforcement audit logs, violations.
 - **E8 AppSec Scanner Agent**
 - Manual docs: AppSec scanning rules, exclusion lists.
 - Outputs: Vulnerability reports, AppSec findings.
-

Domain F – Data Security & Privacy

- **F1 Data Discovery Agent**
 - Manual docs: Data classification policies.
 - Outputs: ClassificationTags, discovery reports.
 - **F2 DLP Monitor Agent**
 - Manual docs: DLP rules, exception requests.
 - Outputs: DLPIncident reports, EnforcementActions.
 - **F3 Crypto Enforcement Agent**
 - Manual docs: Encryption standards, key policies.
 - Outputs: Enforcement audit logs, disputes.
 - **F4 Secure Wipe Agent**
 - Manual docs: Decommission approvals.
 - Outputs: Wipe reports, audit logs.
 - **F5 Integrity Monitor Agent**
 - Manual docs: Baseline manifests.
 - Outputs: IntegrityAlerts, violation reports.
 - **F6 Privacy Enforcement Agent**
 - Manual docs: Privacy impact assessments, lawful basis docs.
 - Outputs: Privacy audit logs, PolicyDispute reports.
-

Domain G – IR & DFIR

- **G1 Incident Triage Agent**
 - Manual docs: Containment playbooks, critical asset maps.
 - Outputs: IncidentClassified reports, DraftContainmentCommands.

- **G2 Automated Containment Agent**
 - Manual docs: HITL tokens for Crown Jewel actions.
 - Outputs: ActionOutcome reports.
 - **G3 Recovery Orchestration Agent**
 - Manual docs: Recovery runbooks, DR plans.
 - Outputs: RecoveryActionOutcome reports.
 - **G4 Forensic Analysis Agent**
 - Manual docs: Forensic collection scopes, warrants/legal docs.
 - Outputs: ForensicReports, evidence packages.
 - **G5 RCA Analysis Agent**
 - Manual docs: RCA templates, lessons learned forms.
 - Outputs: RCAFindings, ChangeIntent records, reports.
 - **G6 Communications Agent**
 - Manual docs: Executive comms templates, legal notice forms.
 - Outputs: IncidentComms updates, RootCauseReports.
-

Domain H – Resilience, Continuity & Recovery

- **H1 Continuity Planning Agent**
 - Manual docs: BCP documents, continuity plan updates.
 - Outputs: BCPUpdate reports, ContinuityChangeImpactReports.
 - **H2 DR Orchestration Agent**
 - Manual docs: DR runbooks, DR plan test approvals.
 - Outputs: DRRunReports, IncidentLink updates.
 - **H3 Resilience Engineering Agent**
 - Manual docs: Chaos experiment definitions.
 - Outputs: ResilienceViolation reports, PolicyChangeProposals.
 - **H4 Failover Automation Agent**
 - Manual docs: Failover plans, HITL overrides.
 - Outputs: FailoverIncidentLink reports, audit logs.
 - **H5 Immutable Backup Agent**
 - Manual docs: Backup policies, restore test approvals.
 - Outputs: BackupViolationEvents, BackupSnapshot reports.
-

Domain I – Security Architecture & Systems Engineering

- **I1 Architecture Advisor Agent**
 - Manual docs: Architecture diagrams, requirements specs.
 - Outputs: ArchReviewFindings, mitigation recommendations.
 - **I2 SSE Process Agent**
 - Manual docs: Project gating criteria.
 - Outputs: SSEChecklistStatus, ReleaseGate decisions.
 - **I3 Crypto Architecture Agent**
 - Manual docs: Crypto requirements docs.
 - Outputs: CryptoDesignDocs, CryptoDecision reports.
 - **I4 Protocol Compliance Agent**
 - Manual docs: Protocol compliance baselines.
 - Outputs: ProtocolComplianceReports, FixTickets.
 - **I5 Pattern Management Agent**
 - Manual docs: New patterns, pattern deprecation proposals.
 - Outputs: PatternUpdates, DeprecationNotices.
 - **I6 DevSecOps Pipeline Agent**
 - Manual docs: CI/CD gate criteria, exception tokens.
 - Outputs: PipelineGateResults, CI/CD audit logs.
-

Domain J – Physical & Environmental Security

- **J1 Physical Access Agent**
 - Manual docs: Access requests/approvals.
 - Outputs: PhysicalAccessDecision, LockdownInitiated events.
- **J2 Video Analytics Agent**
 - Manual docs: Camera placement configs.
 - Outputs: PhysicalAnomalyAlerts, IRVideoEvidenceEvents.
- **J3 Facilities Security Agent**
 - Manual docs: Security plans, facility schematics.
 - Outputs: FacilitySecurityPlans, FacilityUpdate records.
- **J4 OT Monitoring Agent**
 - Manual docs: OT monitoring rules.
 - Outputs: OTAlerts, IROTEvents.
- **J5 Environmental Monitor Agent**
 - Manual docs: Environmental monitoring policies.
 - Outputs: EnvAlerts, EnvRecovery reports.

Domain K – Supply Chain & Lifecycle Security

- **K1 Procurement Policy Agent**
 - Manual docs: RFPs, bid packages, supplier questionnaires.
 - Outputs: ProcurementDecision reports, exception tickets.
- **K2 Authenticity Verification Agent**
 - Manual docs: Signed artifacts, attestations.
 - Outputs: VerificationReports, authenticity alerts.
- **K3 SBOM Analysis Agent**
 - Manual docs: SBOMs from vendors.
 - Outputs: SBOMAnalysisFindings, risk reports.
- **K4 Secure Disposal Agent**
 - Manual docs: Disposal approvals, decommission forms.
 - Outputs: DisposalRecords, violation alerts.

Domain L – Security Program Enablement

- **L1 Security Knowledge Agent**
 - Manual docs: RCA findings, playbooks.
 - Outputs: KB documents, KBUpdate events.
- **L2 Security Analytics Agent**
 - Manual docs: KPI definitions, analytic models.
 - Outputs: AnalyticsFindings, AnalyticsReports.
- **L3 SOAR Orchestration Agent**
 - Manual docs: Runbooks, HITL approvals.
 - Outputs: WorkflowTaskDispatch events, RunbookStatus updates.
- **L4 Data Curation Agent**
 - Manual docs: Labeling guidelines, dataset curation policies.
 - Outputs: CuratedDatasets, DataQualityReports.
- **L5 AI Validation Agent**
 - Manual docs: AI model artifacts, validation criteria.
 - Outputs: ValidationReports, BiasAlerts.

Data Flows

What follows is an attempt to summarize the agent-to-agent inputs and outputs. Please validate designs using agent specifications tailored for your environment and

requirements, as these views may not be all-inclusive. I only list other agents as producers/consumers; when the spec mentions only platforms (IdP, SIEM, PAM, PDP/PEP, IGA, etc.), I show the flow as “—” (since those are systems, not agents), or I annotate likely cross-domain agent consumers in parentheses with “via ...” and keep it conservative. For further information, consult the agent specifications themselves. This is the last section prior to the agents specifications. With the information above and below you should be positioned to endeavor to understand and tailor the agents to your needs.

Domain A – Governance, Risk, and Compliance (GRC) & Oversight

Agent	Accepts inputs from (agents)	Outputs go to (agents)
A1 – Governance Policy Agent	A4 – Policy Authoring Agent (Policy PRs via Git)	SOAR-01, EDR-PEP-01 (PolicyCoSign metadata)
A2 – Risk Analysis Agent	— (ingests SIEM/EDR/CSPM/CMDB/TI, not Domain-A agents)	PATCH-AGENT-01, VULN-AGENT-01, BASELINE-AGENT-01 (PriorityQueue items)
A3 – Compliance Auditor Agent	A1 – Governance Policy Agent (policies via Policy Repository)	— (tickets/evidence/dashboards go to systems)
A4 – Policy Authoring Agent	— (RCA/RT/Reg feeds, not agents)	A1 – Governance Policy Agent (Policy PRs via Git)
A5 – Evidence Collector Agent	— (collects from SIEM/config/tickets/chat)	A1 – Governance Policy Agent (indirect via Evidence Registry: A5→EvidenceManifest→Registry; A1 consumes evidence_refs)
A6 – Control Monitor Agent	— (ingests telemetry from OTel/CSPM/EDR)	A7 – Metrics Aggregator Agent (ControlStatus updates)

Agent	Accepts inputs from (agents)	Outputs go to (agents)
A7 – Metrics Aggregator Agent	A6 – Control Monitor Agent (ControlStatus); SOAR/EDR/orchestrator agents (ActionOutcome)	— (snapshots/dashboards go to registries/BI)
A8 – Supplier Risk Agent	— (questionnaires/SBOMs/attestations from vendors)	SOAR/orchestrator agents (IntegrationPolicy for allow/block/conditional)

Notes

- **Cross-domain inflows:**
 - **A4 (Policy Authoring)** accepts RCA findings, regulatory updates, and risk/threat intel feeds (from G5 RCA Analysis, external regulators, D-domain intel).
 - **A2 (Risk Analysis)** consumes telemetry, CMDB, and threat intelligence from B/D/F domains (but spec lists these as systems, not agents).
 - **A5 (Evidence Collector)** ingests raw evidence from across domains (SIEM, config baselines, tickets, chat transcripts), not agents directly.
- **Cross-domain outflows:**
 - **A1 (Governance Policy Agent)** issues co-signature metadata consumed by **SOAR orchestrators (L3)** and **EDR/PEP containment gateways (E4)**.
 - **A2 (Risk Analysis Agent)** drives **B5 Patch Orchestration**, **B6 Vulnerability Scanning**, and **B2 Baseline Compliance** via PriorityQueues.
 - **A8 (Supplier Risk Agent)** emits IntegrationPolicy decisions consumed by **K1 Procurement Policy Agent** and SOAR/orchestrators.
 - **A7 (Metrics Aggregator)** consumes action outcomes from multiple domains (B/E/G agents) and feeds dashboards used by governance/oversight.
- **Internal loops within Domain A:**
 - **A4 → A1:** Policy authoring proposals flow into governance review.
 - **A1 → A3:** Governance policies feed compliance auditing.
 - **A5 → A1:** Evidence collection supports governance evidence refs.
 - **A6 → A7:** Control monitoring outputs feed metrics aggregation.
- **Role of Governance as hub:**
 - A1 acts as the central **policy gatekeeper**, co-signing enforcement actions across Domains B, E, G, and L.
 - Evidence (A5), authored policies (A4), compliance audits (A3), and metrics

(A6/A7) all consolidate under A1.

– Supplier risk (A8) is where supply chain (Domain K) and governance intersect.

- **Notable gaps:**

- Many outputs target **systems** (GRC dashboards, evidence registries, BI portals) instead of direct agent-to-agent consumers.

- A-domain's authority is strongest at *approval/co-signature points* and in *producing evidence for oversight*, rather than in continuous telemetry exchanges.

Domain B – Asset, Configuration, and Change Management

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
B1 — Asset Discovery	— (ingests systems/APIs only)	B6 (Vuln Scanning) via AssetDiscoveryEvent trigger; also notifies IR-01 (IR agents, Domain G) and IAM-01 (Domain C) via the same stream
B2 — Baseline Compliance	B3 (consumes DriftAlert); B7 (consumes RemediationQueue)	(Primarily to orchestrators/dashboards; no explicit B→B downstream agent listed in spec)
B3 — Config Monitor	— (ingests OTel + CMDB deltas)	B2 (DriftAlert), IR-01 (IR) via DriftAlert; PRs/config sets go to systems
B4 — Change Governance	B2 (ChangeIntent from Baseline/Remediation planners example); B7 (RemediationQueue routes here as an output target); escalations from B5 (on repeated NACK)	Approvals/decisions enable B5 (Patch Orchestration) to proceed in prod (approvals sent to orchestrators/PR gates)
B5 — Patch Orchestration	B7 (RemediationQueue prioritized work); approval signals from B4 (governance gates)	Patch outcomes/events flow to IR-01 and GRC-01 (A-domain); also escalates to B4 on conflicts (NACK)
B6 — Vulnerability Scanning	B1 (AssetDiscoveryEvent triggers scans); also CMDB, etc.,	B7 (VulnFinding consumed for prioritization); IR-01 also consumes VulnFinding

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
	but no other agents listed as inputs	
B7 — Risk Prioritization	B6 (VulnFinding)	B5 (Patch Orchestration), B2 (Baseline Compliance), B4 (Change Governance) via RemediationQueue; also emits reports to GRC/approvers

Notes

- **Cross-domain inflows:**
 - B1 (Asset Discovery) ingests from infrastructure/system APIs (CMDB, cloud, endpoint sources), not agents.
 - Most other B-agents consume telemetry or system outputs; their *agent-to-agent inputs* are primarily within Domain B itself.
- **Cross-domain outflows:**
 - **B1 → C-domain:** AssetDiscoveryEvents notify IAM agents (C1 Provisioning / IAM-01) about new/changed assets.
 - **B1 → G-domain:** The same AssetDiscoveryEvent stream also flows into **IR agents (G1 Triage)**.
 - **B5 Patch Orchestration → A-domain:** Patch outcomes flow back into Governance (A1/A3).
 - **B5 Patch Orchestration → G-domain:** Incident Response consumes PatchOutcome/patch failure signals.
 - **B6 Vuln Scanning → G-domain:** VulnFindings are consumed by IR agents for incident linkage.
 - **B7 Risk Prioritization → A-domain:** Prioritization outputs (RemediationQueue, reports) go into Governance/approvers.
- **Internal loops within Domain B:**
 - B1 → B6 (discovery triggers vuln scanning).
 - B3 → B2 (config drift alerts feed baseline compliance).
 - B7 → B2, B4, B5 (RemediationQueue drives baseline enforcement, change governance, and patch orchestration).
 - B2 ↔ B4 (governance feedback loops; B2 change intents can escalate into governance approvals).
 - B4 ↔ B5 (patch orchestration depends on governance approvals; conflict escalation cycles back).

- **Role of Governance and IR:**
 - Governance (Domain A) gets continuous compliance/audit evidence from B2, B5, B7.
 - IR (Domain G) is a steady consumer of discovery, vuln findings, and patch results.
- **Notable gaps:**
 - B-agents depend heavily on orchestrators, dashboards, and CMDB systems as intermediate carriers; relatively few **direct agent→agent links** are specified outside the B-domain cluster.
 - Human-in-the-loop governance approvals (B4) remain a choke point for B5 to act in production.

Domain C – Identity, Credential, and Access Management (ICAM)

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
C1 · Identity Provisioning	— (inputs are HRIS + Role Catalog systems)	— (SCIM mutations go to IdPs/Apps; AccessChange events go to SIEM/PAM/Data platforms—systems). Note: downstream D-domain monitoring likely consumes via SIEM (“AccessChange”) and G-domain IR may reference deprovision attestations, but not named as agents in spec.
C2 · Auth Policy	— (UEBA/device posture/IdP telemetry are systems/streams)	— (AuthDecision to IdP gateway; IdPPolicyUpdate to IdP config). Optional “AuthAnomalyEvent” goes to SIEM (system), so any D-domain detection agent would see it via SIEM .
C3 · Access Control	— (IGA role mining, entitlement graphs, policy repo—systems)	— (Policy bundles to PDP/PEP; IdP group/attr updates to IdP). Any runtime enforcement agents would consume indirectly through PDP/PEP, not directly named here.
C4 · Privileged Session Monitor	— (consumes PAM telemetry/keystrokes from systems)	— direct: publishes PrivilegedAnomaly/SessionSnapshot to SIEM/case systems; G-domain IR/Case agents would engage via Case Mgmt/DFIR ; real-time block requests go to PAM systems (HITL-gated).

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
C5 · Identity Federation	— (SAML/OIDC/JWKS from partners—systems)	— (Federation configs to IdP/gateways; TrustChange to SIEM/gateway systems). Any D-domain monitoring would receive via SIEM .
C6 · Access Audit	— (Entitlement graph + usage logs from systems)	— (AccessReview/RevokeRecommendation/SoDViolation to IGA/queues/SIEM systems). Governance/oversight A-domain agents could act on SoD signals via GRC/queues , but not explicitly named here.
C7 · Crypto Key Manager	— (CSR/expiry/KMS state from CA/KMS/telemetry systems)	— (certs/rotations/trust-store updates to CA/KMS/gateways; events to queues). No explicit agent consumers named in the C7 excerpt.

Observations

- **Cross-domain inflows:**
 - Most C-agents ingest authoritative system feeds (HRIS, IdP, PAM, IGA, CA/KMS), not other agents. There are no strong *agent* → *agent* input links defined in spec.
 - However, upstream Governance (Domain A) defines identity policy standards and lawful basis (esp. for C6 Access Audit and C7 Crypto Key Manager), even though the spec lists those as system/policy repos rather than explicit agent feeds.
- **Cross-domain outflows:**
 - **C1 (Identity Provisioning):** Emits AccessChange events into SIEM/PAM/Data platforms → consumed downstream by **D-domain monitoring (D2 SIEM Analyst, D3 UEBA)** and potentially **G-domain IR** when investigating deprovision failures.
 - **C2 (Auth Policy):** Emits AuthAnomalyEvents to SIEM → observed by **D2 (SIEM Analyst)**.
 - **C4 (Privileged Session Monitor):** Publishes anomalies/snapshots to SIEM and case mgmt → consumed by **D2 (SIEM Analyst)** and **G1/G4 DFIR agents**.

- **C5 (Identity Federation)**: TrustChange signals go into SIEM/gateway → again visible to **D2**.
- **C6 (Access Audit)**: Emits SoDViolation / RevokeRecommendation → likely routed into Governance (**A3 Compliance Auditor**) or GRC dashboards via queues, though not explicitly named.
- **C7 (Crypto Key Manager)**: Outputs rotations/certs → consumed indirectly by **I3 (Crypto Architecture)** and **F3 (Crypto Enforcement)** agents, but the excerpt doesn't explicitly call them out.
- **Internal loops:**
 - C1 (Provisioning) and C3 (Access Control) are complementary: Provisioning maintains entitlements, while Access Control enforces policy bundles. Their coordination is via IdP/IGA systems rather than direct agent exchange.
 - C4 (Privileged Session Monitor) and C6 (Access Audit) both generate oversight signals (anomalies, SoDViolations) that eventually cycle into compliance and governance loops (Domains A and G).
- **Notable gaps:**
 - Many C-agents act as **first-mile producers** (pushing identity-related telemetry/events into SIEM, PAM, IGA, KMS), leaving downstream consumption to D/G/A domains.
 - The spec intentionally avoids agent-to-agent coupling within C-domain, instead binding through identity infrastructure systems.

Domain D – Threat Intelligence, Situational Awareness, and Monitoring

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
D1 · Threat Intel Aggregator	— (sources are TAXII, OSINT, SIEM sightings, not agents)	Publishes IntellIOC events → consumed by D2 (SIEM Analyst) and D4 (Autonomous Hunter) ; COA recs flow to E-domain (FirewallPolicy E1, EDR Response E4) agents via enforcement systems
D2 · SIEM Analyst	Consumes IntellIOC events from D1 ; also receives anomalies from C2 (Auth Policy) and C4 (Privileged Session Monitor) indirectly via SIEM	Emits DetectionEvents → consumed by G1 (Incident Triage) in Domain G; also forwards enriched anomalies → D3 (UEBA)

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
D3 · UEBA Analysis	Consumes auth anomalies from IdP (but in practice these are outputs of C2 / C4 agents, routed through IdP/SIEM)	Emits UEBA risk scores/events → consumed by D2 (SIEM Analyst) and G1 (Incident Triage)
D4 · Autonomous Hunter	Consumes IntelIOC from D1 and Detection events from D2	Produces HuntFindings → consumed by G1 (Incident Triage) ; may also push prioritized exposures → D5 (Exposure Mapping)
D5 · Exposure Mapping (ASM)	Consumes AssetDiscovery events from B1 (Domain B)	Emits ExposureRecords / RiskHotspots → consumed by D4 (Hunter) and E1 (FirewallPolicy)
D6 · Honeypot Controller	— (no agent feeds, only telemetry)	Emits DeceptionEvents → consumed by D2 (SIEM Analyst) and G1 (Incident Triage)

Observations

- **Cross-domain inflows:**
 - **D2 (SIEM Analyst)** and **D3 (UEBA Analysis)** both indirectly ingest anomalies from **C2 (Auth Policy)** and **C4 (Privileged Session Monitor)** via IdP/SIEM pipelines.
 - **D5 (Exposure Mapping)** consumes **AssetDiscovery events** from **B1 (Asset Discovery, Domain B)** to ground its attack surface analytics.
 - **D1 (Threat Intel Aggregator)** enriches intelligence with internal sightings from SIEM/EDR (system-level, not directly from D2), tightening the loop between telemetry and threat intel.
- **Cross-domain outflows:**
 - **D1 (Threat Intel Aggregator)** feeds **E1 (Firewall Policy Agent)** and **E4 (EDR Response Agent)** with COA recommendations (block/sinkhole/quarantine).
 - **D2 (SIEM Analyst)** emits **DetectionEvents** directly consumed by **G1 (Incident Triage)**, making it the primary bridge into Incident Response.
 - **D3 (UEBA Analysis)** also outputs enriched risk scores into **G1**, complementing SIEM detections with behavioral context.
 - **D5 (Exposure Mapping)** outputs **RiskHotspots** to **E1 (Firewall Policy)** for enforcement of network segmentation/blocks.

- **D6 (Honeypot Controller)** generates DeceptionEvents that flow into **D2 (SIEM Analyst)** and **G1 (Incident Triage)** for adversary detection.
- **Internal loops within Domain D:**
 - **D1 → D2/D4:** Intel drives SIEM enrichment and hunting.
 - **D2 ↔ D3:** SIEM and UEBA share anomalies/risk scores in a feedback loop.
 - **D2/D1 → D4:** Hunter relies on both detections and threat intel for proactive searching.
 - **D4 → D5:** Hunter prioritizes exposures that D5 then maps into RiskHotspots.
 - **D5 → D4/E1:** Attack surface mapping feeds both hunting hypotheses and firewall enforcement.
- **Role of IR (Domain G):**
 - Nearly every D-agent has a downstream tie into **G1 Incident Triage** — via DetectionEvents (D2), UEBA scores (D3), HuntFindings (D4), and DeceptionEvents (D6).
 - This makes Domain D the **primary upstream signal provider** for Incident Response.
- **Role of Protective Tech (Domain E):**
 - Intel and exposure outputs (from D1, D5) flow into **E1/E4** for hardening and active defense.
 - Domain D therefore acts as the *decision intelligence layer* that shapes Domain E enforcement actions.
- **Notable gaps:**
 - D-domain agents rarely consume outputs from other domains besides **B1 and C2/C4**.
 - Most of their “agent-to-agent” relationships are either internal (within D) or outbound into G and E.
 - This reflects Domain D’s design as a **detection-and-analysis hub** rather than an enforcement or governance center.

Domain E – Protective Technologies & Hardening

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
E1 · Firewall Policy Agent	D1 (Threat Intel Aggregator) via IntelIOC; D5 (Exposure Mapping) via RiskHotspot; G-agents (RCAFindings from IR/DFIR)	A1 (Governance Policy Agent) via RuleAuditResult; G-agents via IRPolicyViolationEvent; enforces COAs for D1/D5 via FWRuleChange

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
E2 · IPS Tuning Agent	D2 (SIEM Analyst) via SIEM Detections; G-agents (False Positive Feedback from IR analysts); D1 (Threat Intel) via Intel Feeds	A1 (Governance) via TuningPlan; G-agents via IRPolicyViolationEvent; enforcement to IPS engines
E3 · Zero Trust Segmentation Agent	B1 (Asset Discovery) / CMDB labels; D5 (Exposure Mapping) flows; G-agents (RCAFindings)	A1 (Governance) via PolicyDispute; G-agents via IRPolicyViolationEvent; segmentation enforcement consumed by SDN/NGFW controllers
E4 · EDR Response Agent	D2 (SIEM Analyst) DetectionEvent; EDR Alerts (raw system, not agent)	G1 (Incident Triage) via EDRActionOutcome; A1 (Governance) via PolicyDispute; G-agents via IRPolicyViolationEvent
E5 · Phishing Defense Agent	D1 (Threat Intel) via IntellOC; Mail GW telemetry (system)	G-agents via MaliciousAttachmentReport + IRPolicyViolationEvent; A1 (Governance) via PolicyDispute; detection enrichment back to intel feeds
E6 · Cloud Security Agent	B3 (Config Monitor) DriftAlerts; C-domain IAM agents (misconfigs in cloud posture findings indirectly); G-agents RCAFindings	A1 (Governance) via GuardrailEnforcement audit; G-agents via IRPolicyViolationEvent; pushes CloudFix/GuardrailEnforcement to cloud PEPs
E7 · Baseline Enforcement Agent	B2 (Baseline Compliance) signals; B7 (Risk Prioritization) RemediationQueue	A1 (Governance) via audit logs; G-agents via violation events
E8 · AppSec Scanner Agent	— (findings from CI/CD scans, no direct agent inputs)	B7 (Risk Prioritization) via vuln/issue findings; A1 (Governance) via evidence; G-agents via IRPolicyViolationEvent

Observations

- **Cross-domain inflows:**
 - **E1 (Firewall Policy Agent)** consumes IntelIOCs from **D1 (Threat Intel)**, RiskHotspots from **D5 (Exposure Mapping)**, and RCAFindings from **G4/G5 IR-DFIR agents**.
 - **E2 (IPS Tuning Agent)** consumes detections from **D2 (SIEM Analyst)**, intel from **D1**, and FP feedback from **G-agents**.
 - **E3 (Zero Trust Segmentation Agent)** consumes asset context from **B1 (Asset Discovery)**, exposures from **D5**, and RCA findings from **G-agents**.
 - **E4 (EDR Response Agent)** consumes detections from **D2**.
 - **E5 (Phishing Defense Agent)** consumes IntelIOC from **D1**.
 - **E6 (Cloud Security Agent)** consumes DriftAlerts from **B3 (Config Monitor)**, misconfig alerts indirectly from **C-domain IAM agents**, and RCA findings from **G-agents**.
 - **E7 (Baseline Enforcement Agent)** consumes compliance signals from **B2** and remediation queues from **B7**.
 - **E8 (AppSec Scanner Agent)** is standalone, triggered by CI/CD scans rather than another agent.
- **Cross-domain outflows:**
 - Nearly every E-agent sends governance evidence (RuleAuditResult, PolicyDispute, GuardrailEnforcement audit, baseline enforcement logs, AppSec evidence) to **A1 (Governance Policy Agent)**.
 - Enforcement outcomes are reported to **G-agents (IR/DFIR)** as **IRPolicyViolationEvents** or **MaliciousAttachmentReports**.
 - **E1** and **E5** feed enriched detections back into **D1 (Threat Intel)** for IOC expansion.
 - **E4 (EDR Response Agent)** outputs EDRActionOutcome directly to **G1 (Incident Triage)**.
 - **E8 (AppSec Scanner Agent)** outputs findings into **B7 (Risk Prioritization)** for remediation planning.
- **Internal loops within Domain E:**
 - Shared enforcement patterns (E1 firewall rules, E2 IPS signatures, E3 ZT segmentation, E6 cloud guardrails, E7 baseline controls) all funnel policy disputes and audit artifacts into A1.
 - Multiple E-agents (E1, E2, E3, E4, E5, E6, E7, E8) report violations and enforcement outcomes into G-domain agents for incident triage and RCA.
- **Role of Governance (A1):**
 - A1 acts as **auditor and arbiter** for all protective actions: every E-agent

provides evidence or disputes for governance tracking.

– This creates a strong vertical loop between hardening/enforcement (E) and oversight (A).

- **Role of IR (Domain G):**

– E-agents supply **violation events** to G1 triage and forensic flows, ensuring that protective failures or escalations are captured in incident response.

– **E4** is directly wired into G1, making endpoint response the tightest E↔G coupling.

- **Role of Threat Intel (Domain D):**

– D1/D2/D5 feed E1, E2, E3 with actionable intel and exposure maps.

– E-agents return enriched results (E5 phishing detections, E1 firewall enforcement feedback) to D1 for threat intelligence improvement.

- **Role of Asset/Config (Domain B):**

– E3 relies on B1 (assets) and B3 (configs), while E7 consumes baseline and remediation signals from B2/B7.

– E8 feeds back into B7 for remediation pipelines.

- **Notable gaps:**

– E-agents are primarily **consumers** of intel and compliance signals, and **producers** of governance/IR evidence.

– Direct **E-to-E links** are minimal; the architecture relies on shared systems (controllers, cloud PEPs, CI/CD) rather than explicit agent coupling.

Domain F – Data Security & Privacy

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
F1 · Data Discovery Agent	— (only consumes repos/flows directly)	F2 (DLP Monitor) via ClassificationTag for DLP enforcement; A1 Governance via PolicyDispute/ChangeImpactReport; G-agents (IR) via IRPolicyViolationEvent
F2 · DLP Monitor Agent	F1 (ClassificationTag) for asset tags/policy bindings; also UEBA risk from D3 in Domain D (via SIEM)	G1 Incident Triage via DLPIncident & IRPolicyViolationEvent; E4 (EDR Response) via EnforcementAction (block/quarantine); A1 Governance via PolicyDispute/ChangeImpactReport

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
F3 · Crypto Enforcement Agent	— (inputs are KMS events + config scans, not agents)	A1 Governance via PolicyDispute/ChangeImpactReport; G-agents (IR) via IRPolicyViolationEvent
F4 · Secure Wipe Agent	B2 (Baseline Compliance) indirectly via decommission orders from CMDB/ITSM	A1 Governance via PolicyDispute/ChangeImpactReport; G-agents (IR) via IRPolicyViolationEvent
F5 · Integrity Monitor Agent	B3 (Config Monitor) may supply manifests; also consumes attestations/beacons (not agents)	G1 Incident Triage via IntegrityAlert & IRPolicyViolationEvent; A1 Governance via PolicyDispute/ChangeImpactReport
F6 · Privacy Enforcement Agent	F1 (Data Discovery) via ClassificationTags for data categories; A1 Governance provides policies/lawful basis via registry	A1 Governance via PolicyDispute/ChangeImpactReport; G-agents (IR) via IRPolicyViolationEvent

Here's the **Observations for Domain F – Data Security & Privacy**, aligned in the same style as Domains A–E:

Observations for Domain F – Data Security & Privacy

- **Cross-domain inflows:**
 - **F2 (DLP Monitor)** consumes ClassificationTags from **F1 (Data Discovery)** and UEBA risk from **D3 (UEBA Analysis)** via SIEM.
 - **F4 (Secure Wipe)** indirectly consumes decommission signals from **B2 (Baseline Compliance)** via CMDB/ITSM flows.
 - **F5 (Integrity Monitor)** may ingest manifests from **B3 (Config Monitor)**.
 - **F6 (Privacy Enforcement)** consumes ClassificationTags from **F1** and lawful basis policies from **A1 Governance**.
- **Cross-domain outflows:**
 - All F-agents send **PolicyDisputes** or **ChangeImpactReports** into **A1**

Governance for oversight.

- Every F-agent can emit **IRPolicyViolationEvents** into **G1 (Incident Triage)** when data security/privacy violations occur.

- **F2 (DLP Monitor)** sends **EnforcementAction** commands to **E4 (EDR Response Agent)** to block/quarantine malicious file events.

- **F5 (Integrity Monitor)** sends **IntegrityAlerts** to **G1 Incident Triage** to drive investigations of tampering.

- **Internal loops within Domain F:**

- **F1** → **F2**: Discovery classifications feed DLP enforcement.

- **F1** → **F6**: Data categories/classification inform privacy enforcement.

- This establishes F1 as the upstream "feeder" for enforcement-focused F-agents.

- **Role of Governance (Domain A):**

- A1 is the universal sink for F-domain evidence: PolicyDisputes, lawful basis checks, and change-impact reports flow back into Governance.

- This reflects privacy/security's dependence on **policy interpretation and oversight**.

- **Role of Incident Response (Domain G):**

- All F-agents emit violation events to G1.

- **F2 (DLP)** and **F5 (Integrity Monitor)** produce direct detection signals (DLPIncidents, IntegrityAlerts).

- **F3, F4, F6** escalate primarily via violation event patterns.

- **Role of Protective Tech (Domain E):**

- **F2 (DLP Monitor)** integrates directly with **E4 (EDR Response)** for enforcement of block/quarantine, making it one of the stronger cross-domain operational couplings.

- **Notable gaps:**

- With the exception of F1→F2/F6, there is little **intra-domain F→F communication**; most coordination happens outward through governance or incident response.

- F-agents often depend on **systems** (CMDB, KMS, ITSM, classification registries) as intermediaries, with relatively few direct agent-to-agent contracts.

Domain G – Incident Response & Digital Forensics (IR-DFIR)

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
G1 · Incident Triage	D2 (SIEM Analyst) via DetectionEvents; D3 (UEBA Analysis) via AuthAnomalies; F2 (DLP Monitor) via DLPIncident; F5 (Integrity Monitor) via IntegrityAlert	G2 (Automated Containment) via ContainmentProposalDraft; G6 (Comms) via IncidentClassified/updates; G4 (Forensic Analysis) via case linkage; G3 (Recovery Orchestration) after containment
G2 · Automated Containment	G1 (Incident Triage) via ContainmentCommand	G1 (Incident Triage) via ActionOutcome feedback; G3 (Recovery Orchestration) (triggered when containment complete); G6 (Comms) via incident updates (containment status)
G3 · Recovery Orchestration	G1 (Incident Triage) (indirectly via incident mgmt system); G2 (Automated Containment) (handoff after containment)	G6 (Comms) (RecoveryActionOutcome to stakeholders); G5 (RCA Analysis) via timelines
G4 · Forensic Analysis	G1 (Incident Triage) (case linkage provides evidence sets); ingestion of artifacts triggered by containment (G2)	G5 (RCA Analysis) via RCAFindings; A1 (Governance) via ControlDefectRecord (indirect)
G5 · RCA Analysis	G4 (Forensic Analysis) via RCAFindings; G3 (Recovery Orchestration) via Incident Timelines	A1 (Governance) via ControlDefectRecord & ChangeIntent; B2/B7 (Baseline/Remediation) via ChangeIntent; G6 (Comms) (RootCauseReport to exec/legal audiences)
G6 · Communications	G1 (Incident Triage) via Incident Updates; G2 (Containment) , G3	External stakeholders (not agents); but internally it reinforces A1

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
	(Recovery) , G5 (RCA) via incident phases and RCA Reports	(Governance) (distribution audits for compliance)

Observations

- **Cross-domain inflows:**
 - **G1 (Incident Triage)** is the primary sink for upstream detections and alerts:
 - **D2 (SIEM Analyst)** → DetectionEvents.
 - **D3 (UEBA Analysis)** → AuthAnomalies.
 - **F2 (DLP Monitor)** → DLPIncidents.
 - **F5 (Integrity Monitor)** → IntegrityAlerts.
 - **G4 (Forensic Analysis)** may indirectly receive containment artifacts triggered by **E4 (EDR Response)** or other E-domain enforcement actions.
- **Cross-domain outflows:**
 - **G4 (Forensic Analysis)** and **G5 (RCA Analysis)** generate **ControlDefectRecords** and **ChangeIntent**s that flow into **A1 Governance** and **B2/B7 Baseline & Remediation**.
 - **G5 (RCA Analysis)** also produces RCA lessons that loop back into **I5 (Pattern Management)** and **L1 (Knowledge)** (not explicit in this slice, but described in Domain I/L specs).
 - **G6 (Comms)** pushes structured incident updates and RCA summaries to **A1 Governance** for compliance distribution.
- **Internal loops within Domain G:**
 - **G1 → G2 → G3 → G4 → G5 → G6** forms the canonical IR/DFIR pipeline:
 - G1 triages and drafts containment.
 - G2 executes containment.
 - G3 handles recovery.
 - G4 investigates forensics.
 - G5 analyzes root cause.
 - G6 communicates outcomes.
 - Feedback loops:
 - G2 → G1 (ActionOutcome).
 - G3 → G5 (timelines for RCA).
 - G5 → G6 (RootCauseReport).

- **Role of Governance (Domain A):**
 - A1 consumes **ControlDefectRecords**, **PolicyDisputes**, **ChangeIntents** from G4/G5.
 - A1 also receives **distribution audits** from G6 to validate regulatory notification compliance.
- **Role of Asset/Change Mgmt (Domain B):**
 - G5 outputs ChangeIntents to **B2 (Baseline Compliance)** and **B7 (Risk Prioritization)**, driving remediation planning.
- **Role of Threat Intel (Domain D):**
 - D2 and D3 are the frontline feeders of events into G1.
 - Without Domain D signals, G-domain agents would not have context for classification and containment.
- **Role of Protective Tech (Domain E):**
 - G1/G2 containment decisions often map to **E1/E4/E6 enforcement** (via SOAR/PEP gateways).
 - Violations discovered in E feed back into G triage for new incidents.
- **Notable gaps:**
 - Domain G agents rely heavily on **incident management systems** as intermediaries; most intra-domain links are case/ticket-driven rather than direct RPCs.
 - No explicit G→D feedback loop is described, even though in practice forensic IOCs (G4/G5) could enrich D1 Threat Intel.

Domain H – Resilience, Continuity, and Recovery

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
H1 · Continuity Planning Agent	— (inputs are BCM/GRC, risk, regs; no direct agent feeds)	A1 (Governance Policy Agent) via BCPUpdatePublish, ContinuityChangeImpactReport; G1 (Incident Triage) via IRContinuityViolationEvent
H2 · DR Orchestration Agent	G1 (Incident Triage) indirectly via Outage Alerts/Incident Webhooks	G1/G2/G3 (IR/Containment/Recovery) via IRDRIncidentLink; A1 Governance via DRRunReport (audit evidence)

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
H3 · Resilience Engineering Agent	A1 (Governance) (policies/guardrails repo); H5 (Immutable Backup) indirectly (backup/restore status for chaos tests)	G1 (Incident Triage) via IRResilienceViolationEvent; A1 Governance via PolicyChangeProposal (playbook/guardrail changes)
H4 · Failover Automation Agent	D2 (SIEM Analyst) / Monitoring agents indirectly via SLO/health signals	G1 (Incident Triage) via IRFailoverIncidentLink; A1 Governance via FailoverEvent logs for audit
H5 · Immutable Backup Agent	— (consumes Backup Job configs + KMS state, not agents)	G1 (Incident Triage) via IRBackupViolationEvent; A1 Governance via BackupSnapshot/RestoreTestResult; H3 (Resilience Eng.) consumes restore/test results for chaos validation

Observations

- **Cross-domain inflows:**
 - **H2 (DR Orchestration)** indirectly consumes outage/incident alerts from **G1 (Incident Triage)** via incident webhooks.
 - **H3 (Resilience Engineering)** consumes governance guardrails/policies from **A1 Governance**, and test results from **H5 Immutable Backup**.
 - **H4 (Failover Automation)** consumes health/SLO signals from **D2 (SIEM Analyst)** and monitoring agents in D-domain.
- **Cross-domain outflows:**
 - Every H-agent sends audit evidence and change-impact reports into **A1 Governance** (e.g., BCPUUpdate, DRRunReport, PolicyChangeProposal, FailoverEvent, BackupSnapshot).
 - All resilience violations and continuity/backup/failover incidents are routed into **G1 (Incident Triage)**:
 - H1 → IRContinuityViolationEvent.
 - H2 → IRDRIncidentLink.
 - H3 → IRResilienceViolationEvent.
 - H4 → IRFailoverIncidentLink.
 - H5 → IRBackupViolationEvent.

- **Internal loops within Domain H:**
 - **H5** → **H3**: Backup/restore validation feeds resilience experiments.
 - **H1** → **H2/H4** indirectly: Continuity planning documents define the playbooks H2 (DR) and H4 (Failover) execute against.
- **Role of Governance (Domain A):**
 - A1 is the **compliance sink** for all H-domain agents. Governance collects continuity plan updates, DR evidence, backup test results, and policy change proposals for audit and oversight.
- **Role of Incident Response (Domain G):**
 - G1 consumes all continuity/backup/failover violation events from H-domain. This creates a strong dependency where resilience issues are triaged in the same workflows as security incidents.
 - G2/G3 are linked by **H2 DR Orchestration**, which provides DRIncidentLinks during active outages.
- **Role of Monitoring/Intel (Domain D):**
 - D2 provides the health/SLO signals that trigger failover automation in **H4**.
- **Notable gaps:**
 - H-domain agents are **heavy producers** of evidence and violation events but have relatively few inbound agent feeds.
 - Most inflows are from systems (BCM, monitoring, KMS) rather than other agents, with **A1 Governance** being the only explicit cross-domain input provider.

Domain I – Security Architecture & Systems Engineering (SASE)

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
I1 · Architecture Advisor	— (consumes diagrams/reqs from repos, not agents)	A1 Governance (ArchReviewFindings, tickets, PR comments); I5 (Pattern Mgmt) (review findings feed pattern updates)
I2 · SSE Process Agent	— (consumes project mgmt + CI/CD events)	A1 Governance (SSEChecklistStatus for compliance oversight); I6 (DevSecOps Pipeline) via ReleaseGateDecision/PR comments (shared gating context)
I3 · Crypto Architecture Agent	— (requirements + CMDB assets, not agents)	A1 Governance (CryptoDesignDoc, CryptoDecisions); F3 Crypto

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
		Enforcement (downstream enforces designs)
I4 · Protocol Compliance Agent	— (traffic captures + configs, not agents)	A1 Governance (ProtocolComplianceReport, FixTickets); I5 (Pattern Mgmt) (findings reused to update patterns)
I5 · Pattern Management Agent	I1 (Arch Advisor) via ArchReviewFindings; G5 (RCA Analysis) via RCA lessons	A1 Governance (PatternUpdate, DeprecationNotice); I6 (DevSecOps Pipeline) (patterns feed CI/CD gates)
I6 · DevSecOps Pipeline Agent	I2 (SSE Process) (gating context); I5 (Pattern Mgmt) (patterns, constraints)	A1 Governance (PipelineGateResult); B7 (Risk Prioritization) (issues feed remediation queue); G-agents (incident-linked waivers, via governance)

Observations

- **Cross-domain inflows:**
 - **I5 (Pattern Management)** consumes RCA lessons from **G5 (RCA Analysis)** to evolve architectural/security patterns.
 - **I3 (Crypto Architecture)** aligns with asset/configuration data (from B-domain systems, not agents).
 - **I6 (DevSecOps Pipeline)** may be influenced indirectly by **G-domain IR agents** when incident waivers/exception requests are routed through governance.
- **Cross-domain outflows:**
 - Every I-agent produces governance evidence (checklists, review findings, crypto docs, compliance reports, pattern updates, pipeline gate results) into **A1 Governance**.
 - **I3 (Crypto Architecture)** outputs designs consumed downstream by **F3 (Crypto Enforcement)** in the Data Security domain.
 - **I6 (DevSecOps Pipeline)** sends issues into **B7 (Risk Prioritization)** for remediation work.
 - **I5 (Pattern Management)** updates patterns that influence future CI/CD enforcement in I6 and indirectly strengthen responses in other domains.

- **Internal loops within Domain I:**
 - **I1** → **I5**: Architecture reviews feed pattern updates.
 - **I2** → **I6**: SSE process gates influence pipeline release decisions.
 - **I5** → **I6**: Patterns/constraints define pipeline gates and CI/CD security controls.
 - **I6** → **A1 Governance** closes the compliance feedback loop by recording release-gate results.
- **Role of Governance (Domain A):**
 - A1 is the universal sink for I-domain outputs: ArchReviewFindings, SSEChecklistStatus, CryptoDecisions, ProtocolComplianceReports, PatternUpdates, and PipelineGateResults.
 - Governance uses this evidence to validate that systems engineering and architecture practices align with compliance frameworks.
- **Role of Data Security (Domain F):**
 - **I3** → **F3**: Crypto architecture decisions are directly enforced by crypto enforcement agents.
- **Role of Incident Response (Domain G):**
 - **I5 (Pattern Mgmt)** ingests RCA lessons from **G5 (RCA Analysis)**, creating a direct learning loop from incidents to architectural standards.
 - **I6 (Pipeline Agent)** also produces governance-linked exception waivers that G-agents may influence during incident-driven remediation.
- **Notable gaps:**
 - I-domain agents mostly consume inputs from **systems (repos, CI/CD, configs, captures)** rather than other agents, with **G5** → **I5** being the notable exception.
 - Outputs are heavily biased toward compliance evidence (into A1), making Domain I more of a **standards/patterns authority** than a detection/enforcement layer.

Domain J – Physical & Environmental Security

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
J1 · Physical Access Agent	— (joins incident “missions” via the incident platform; no direct agent producer stated)	G1 (Incident Triage) via IRPhysicalAccessEvent (incident REST attach); D2 (SIEM Analyst) via PhysicalAccessDecision + LockdownInitiated events (to SIEM/SOAR bus)

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
J2 · Video Analytics Agent	— (ingests video/model artifacts; no direct agent inputs)	G1 (Incident Triage) via IRVideoEvidenceEvent (incident REST attach); D2 (SIEM Analyst) via PhysicalAnomalyAlert (to SIEM/SOAR bus)
J3 · Facilities Security Agent	— (ingests BIM/CAD + risk assessments; no direct agent inputs)	— (publishes FacilitySecurityPlan/updates/work items to plan registry/CMMS/PACS/VMS; no explicit agent consumers named)
J4 · OT Monitoring Agent	— (ingests PLC/SCADA + OT network flows; no direct agent inputs)	G1 (Incident Triage) via IROTEvent (incident REST attach); D2 (SIEM Analyst) via OTAlert (to SIEM/SOAR bus)
J5 · Environmental Monitor Agent	— (ingests BACnet/SNMP; no direct agent inputs)	G1 (Incident Triage) via IncidentNotification (incident REST/paging); D2 (SIEM Analyst) via EnvAlert/EnvRecovery (to SIEM/SOAR bus)

Observations

- **Cross-domain inflows:**
 - J-domain agents primarily consume **system-level telemetry** (PACS, VMS, OT PLC/SCADA, environmental sensors), not other agents.
 - The only explicit “agent-aware” interaction is **J1** joining missions via the incident platform, which ties into **G1 Incident Triage** workflows.
- **Cross-domain outflows:**
 - **J1 (Physical Access Agent)** sends IRPhysicalAccessEvents into **G1 Incident Triage**, and PhysicalAccessDecision/Lockdown events into **D2 SIEM Analyst** via SIEM/SOAR.
 - **J2 (Video Analytics Agent)** sends IRVideoEvidenceEvents into **G1**, and anomaly alerts into **D2**.
 - **J4 (OT Monitoring Agent)** outputs IROTEvents into **G1** and OTAlerts into **D2**.
 - **J5 (Environmental Monitor Agent)** outputs IncidentNotifications into **G1** and EnvAlerts/Recovery into **D2**.
 - **J3 (Facilities Security Agent)** produces FacilitySecurityPlans and updates,

but no direct agent consumers are listed — its outputs are aimed at systems like CMMS/PACS/VMS.

- **Internal loops within Domain J:**
 - No direct J→J agent loops are described; each agent operates as an isolated sensor/controller aligned with a different physical or environmental layer (access, video, facilities, OT, environmental).
- **Role of Incident Response (Domain G):**
 - **G1 Incident Triage** is the primary consumer of J-domain outputs (IRPhysicalAccessEvent, IRVideoEvidenceEvent, IROTEvent, IRBackupViolationEvent).
 - This places J-domain agents as **first-mile feeders of physical incident evidence** into the same case management system used for cyber incidents.
- **Role of Threat Intel/Monitoring (Domain D):**
 - **D2 SIEM Analyst** consumes all anomaly/alert outputs from J1, J2, J4, J5.
 - This extends SIEM's coverage from cyber telemetry into physical/OT/environmental monitoring.
- **Notable gaps:**
 - **J3 (Facilities Security)** stands apart: while it produces security plan outputs, there are no explicitly named agent consumers; instead, its outputs are aimed at facilities/operations systems.
 - No strong “feedback loops” back into J-domain from other domains are specified — J-agents primarily **export evidence/alerts** without much inbound agent-to-agent data.

Domain K – Supply Chain & Lifecycle Security

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
K1 · Procurement Policy Agent	A8 Supplier Risk Agent (uses supplier risk scores)	A1 Governance (ProcurementDecision events into oversight dashboards); Legal/Risk workflows via remediation tickets; indirectly affects K2/K3 by requiring authenticity & SBOM checks
K2 · Authenticity Verification Agent	K1 Procurement Policy Agent (RFP artifact chain-of-custody requirements); A8	K3 SBOM Analysis (signed SBOMs, verified attestations); A1 Governance (verification results / evidence trail); G1 Incident Triage if authenticity violation triggers supply-chain incident

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
	Supplier Risk Agent (risk score linkage)	
K3 · SBOM Analysis Agent	K1 Procurement Policy Agent (bid package SBOMs); K2 Authenticity Verification (validated SBOMs)	A1 Governance (SBOMAnalysisFindings into compliance/risk repos); B6 Vulnerability Scanning (feeds package lists for vuln scans); G1 Incident Triage (alerts on malicious/poisoned deps)
K4 · Secure Disposal Agent	— (inputs are CMDB/Asset Disposal tickets; no explicit agent feeds)	B1 Asset Discovery / B4 Change Governance (disposal updates); A1 Governance (DisposalRecord for compliance evidence); G1 Incident Triage (if disposal violation event)

Observations

- **Cross-domain inflows:**
 - **K1 (Procurement Policy Agent)** consumes supplier risk scores from **A8 (Supplier Risk Agent)** in the Governance domain to factor into procurement decisions.
 - **K2 (Authenticity Verification Agent)** consumes requirements from **K1** (chain-of-custody expectations) and also leverages **A8 Supplier Risk Agent** data.
 - **K3 (SBOM Analysis Agent)** consumes SBOMs from **K1** (bid packages) and validated attestations from **K2**.
 - **K4 (Secure Disposal Agent)** consumes lifecycle triggers indirectly via **CMDB/Asset Disposal systems**, not from agents.
- **Cross-domain outflows:**
 - **K1** sends ProcurementDecision events into **A1 Governance** and spawns legal/risk workflows via remediation tickets. It also drives downstream expectations for **K2/K3**.
 - **K2** outputs verification results to **A1 Governance**, validated SBOMs to **K3**, and violation signals to **G1 Incident Triage** if authenticity fails.
 - **K3** outputs SBOMAnalysisFindings to **A1 Governance**, package lists to **B6 (Vulnerability Scanning)** for ongoing vuln management, and alerts to **G1 Incident Triage** if malicious or poisoned dependencies are detected.
 - **K4** updates **B1 (Asset Discovery)** and **B4 (Change Governance)** with

lifecycle/disposal records, produces DisposalRecords for **A1 Governance**, and raises incidents into **G1** if disposal is mishandled.

- **Internal loops within Domain K:**
 - **K1 → K2 → K3:** Procurement policy requires authenticity verification, which feeds SBOM analysis for software assurance.
 - **K4** is somewhat standalone, focusing on the asset end-of-life stage rather than procurement/analysis.
- **Role of Governance (Domain A):**
 - A1 is the **compliance sink** for all K-agents: procurement decisions, authenticity verification evidence, SBOM findings, and disposal records all flow into Governance oversight dashboards.
 - This mirrors the “audit-heavy” pattern seen in other domains like F and H.
- **Role of IR/DFIR (Domain G):**
 - **K2** and **K3** both escalate supply-chain security violations to **G1 (Incident Triage)**, integrating supply chain issues into the same workflows as cyber incidents.
 - **K4** does the same for disposal-related violations.
- **Role of Asset/Config (Domain B):**
 - **K3** feeds vulnerability-relevant package lists into **B6 (Vulnerability Scanning)** for continuous monitoring.
 - **K4** informs **B1 (Asset Discovery)** and **B4 (Change Governance)** of disposal actions to maintain asset lifecycle accuracy.
- **Notable gaps:**
 - Aside from the K1–K2–K3 pipeline, there’s little intra-domain agent-to-agent interaction; K4 operates largely independently.
 - Inputs are heavily **document-driven** (RFPs, SBOMs, attestations), reinforcing that K-domain relies more on *manual artifacts plus verification agents* than on continuous telemetry.

Domain L – Security Program Enablement

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
L1 · Security Knowledge Agent	G5 (RCA Analysis) via RCA Findings; L3 (SOAR Orchestration) via RunbookCompletedEvent; playbooks from repos (not agents)	L2 (Analytics) and L3 (SOAR) via KBUpdateEvent; A1 (Governance) via KB updates/disputes

Agent	Accepts inputs from (agents)	Sends outputs to (agents)
L2 · Security Analytics Agent	A7 (Metrics Aggregator) via MetricSnapshot; SOAR/IR agents (e.g., G2 , B5) via ActionOutcome	SOAR (L3) and SIEM (D2) via AnalyticsFinding; Exec dashboards / A1 Governance via AnalyticsReport
L3 · SOAR Orchestration Agent	D2 (SIEM Analyst) via DetectionEvents; G1 (Incident Triage) via ContainmentCommand; A1 (Governance) via PolicyCoSign requirement; L1 (Knowledge) via playbooks	G2 (Automated Containment) , E4 (EDR Response) , C3 (Access Control) , B5 (Patch Orchestration) , F5 (Evidence Collector) , etc. via WorkflowTaskDispatch; A1 (Governance) via RunbookStatusEvent; L1 (Knowledge) via RunbookCompletedEvent
L4 · Data Curation Agent	Telemetry feeds (OTel, etc.); Labels (no direct agent feeds)	L5 (AI Validation Agent) via CuratedDataset; A1 (Governance) via LeakageAlert / DataQualityReport
L5 · AI Validation Agent	L4 (Data Curation Agent) via CuratedDataset; Model artifacts (system registry)	A1 (Governance) via ValidationReport / BiasAlert; Deployment gates (CI/CD) indirectly; Exec portal

Observations

- **Cross-domain inflows:**
 - **L1 (Security Knowledge Agent)** ingests RCA Findings from **G5 (RCA Analysis)** and completed runbooks from **L3 (SOAR)** to normalize them into KB entries.
 - **L2 (Security Analytics Agent)** consumes MetricSnapshots from **A7 (Metrics Aggregator)** and ActionOutcomes from multiple execution agents across domains (e.g., **G2 Containment**, **B5 Patch Orchestration**, **E4 EDR Response**).
 - **L3 (SOAR Orchestration Agent)** consumes DetectionEvents from **D2 (SIEM Analyst)**, ContainmentCommands from **G1 (Incident Triage)**, PolicyCoSign approvals from **A1 (Governance)**, and playbooks from **L1 (Knowledge)**.
 - **L4 (Data Curation Agent)** ingests telemetry and labeling streams (no direct agent-to-agent input).

- **L5 (AI Validation Agent)** consumes curated datasets from **L4** and model artifacts from system registries.
- **Cross-domain outflows:**
 - **L1** publishes KBUpdateEvents to **L2 (Analytics)** and **L3 (SOAR)**, and also provides KB updates/disputes to **A1 (Governance)**.
 - **L2** outputs AnalyticsFindings to **L3 (SOAR)** and **D2 (SIEM Analyst)**, and AnalyticsReports to executive dashboards and **A1 Governance**.
 - **L3** orchestrates workflow tasks directly to execution agents across domains: **G2 (Containment)**, **E4 (EDR Response)**, **C3 (Access Control)**, **B5 (Patch Orchestration)**, **F5 (Evidence Collector)**, etc. It also reports runbook status into **A1 Governance** and runbook completions back to **L1**.
 - **L4** sends curated datasets to **L5**, and leakage/data quality reports to **A1 Governance**.
 - **L5** outputs ValidationReports and BiasAlerts to **A1 Governance**, and indirectly gates deployments in CI/CD.
- **Internal loops within Domain L:**
 - **L1 ↔ L3:** Knowledge Agent provides playbooks to SOAR; SOAR returns completed runbooks to Knowledge for KB curation.
 - **L1 → L2:** KB updates feed analytics models.
 - **L2 → L3:** Analytics findings flow into SOAR playbooks and orchestration.
 - **L4 → L5:** Data curation produces datasets for validation.
 - **L5 → A1** closes the loop by auditing AI/ML models for compliance and governance.
- **Role of Governance (Domain A):**
 - A1 consumes outputs from **every L-agent**: KB updates (L1), AnalyticsReports (L2), RunbookStatusEvents (L3), DataQualityReports (L4), ValidationReports/BiasAlerts (L5).
 - This reinforces Governance’s role as the **oversight hub** not just for operations but also for knowledge, analytics, and AI lifecycle management.
- **Role of Threat Detection/IR (Domains D & G):**
 - **D2 (SIEM Analyst)** and **G1 (Triage)** feed L3 (SOAR) with events and containment commands, making SOAR the bridge between detection and automated response.
 - **G5 (RCA Analysis)** feeds lessons into L1, closing the loop from incidents to institutional knowledge.
- **Role of Execution Agents (Domains B, C, E, F, G):**
 - L3 directly dispatches tasks to containment (G2), endpoint response (E4), identity enforcement (C3), patch orchestration (B5), and evidence collection (F5).
 - This makes L3 the **operational control plane** across domains.

- **Notable gaps:**
 - L4 (Data Curation) and L5 (AI Validation) are inward-facing, with few direct cross-domain inputs; their main cross-domain impact comes through reports into Governance.
 - SOAR (L3) is by far the **most connected agent**, acting as the orchestrator across domains, while L1 and L2 focus more on **knowledge and analytics enrichment**.